Cyber Security / Information Security — Short Complete Roadmap 🔐

Yeh main topics hain jo BS-level exams aur Cyber Security ki foundation ke liye cover karne chahiye.

Roadmap — 12 Main Topics

1. Security Fundamentals

- Information Security vs Cyber Security
- CIA Triad (Confidentiality, Integrity, Availability)
- AAA (Authentication, Authorization, Accounting)
- Threats, vulnerabilities, risks and security controls

2. Security Attacks & Malware

- Virus, worm, Trojan, ransomware, spyware
- Phishing, spoofing, social engineering
- DoS/DDoS, passive vs active attacks

3. Cryptography

- Encryption vs decryption, plaintext vs ciphertext
- Symmetric vs asymmetric encryption
- DES, 3DES, AES, RSA
- Hashing, digital signatures, digital certificates

4. Authentication & Access Control

- Passwords, MFA, biometrics
- Authentication vs authorization
- DAC, MAC, RBAC
- Least privilege

5. Network Security

- Firewalls, IDS vs IPS
- VPN, HTTPS/TLS, SSH
- Network attacks and Wi-Fi security

6. System & Database Security

- Windows/Linux security
- User permissions and access control
- Database security, backups and recovery

7. Web & Application Security

- SQL Injection, XSS, CSRF
- Secure coding and OWASP Top 10

8. Risk Management & Security Policies

- Risk assessment and mitigation
- Security policies and standards
- ISO 27001 and NIST basics

9. Security Models & Principles

- Bell–LaPadula and Biba models
- Defense in depth, zero trust
- Separation of duties

10. Ethical Hacking & Security Tools

- Reconnaissance and vulnerability assessment
- Kali Linux basics
- Nmap, Wireshark, Burp Suite
- Authorized penetration testing

11. Incident Response & Digital Forensics

- Detection, containment, recovery
- Logs, digital evidence and chain of custody
- Backup and disaster recovery

12. Final Revision & Exam Practice

- Important definitions and differences
- MCQs and short questions
- Long questions and practical examples

Important exam topics ★

CIA Triad, AAA, malware, passive vs active attacks, DES vs AES vs RSA, symmetric vs asymmetric encryption, hashing, digital signatures, firewall vs IDS/IPS, access-control models, and risk management.

Hum DBMS ki tarah Topic 1 se start karenge, aur har topic mein definitions, types, examples aur exam questions cover karenge.

chlo ab topic one se start kro but sath sath topics ki real world example b deni jhae

Topic 1: Security Fundamentals 🔐

Aaj hum Cyber Security ke basics parhenge. Har concept ke saath definition, types where applicable, aur real-world example bhi hoga.

1. What is Information Security?

Definition: Information Security (InfoSec) is the practice of protecting information from unauthorized access, use, modification, disclosure, or destruction.

Real-world example: A university protects students' records, marks, and personal details so unauthorized people cannot view or change them.

2. Information Security vs Cyber Security

- Information Security: Protects information in every form, including digital files and paper documents.
- Cyber Security: Protects computers, networks, applications, and digital information from cyber threats.

Real-world example: Locking a paper examination record in a cabinet is Information Security. Protecting the university's online examination portal from hackers is Cyber Security.

3. CIA Triad — Three Main Security Principles



C — Confidentiality

Definition: Ensures that information is accessible only to authorized people.

Example: Only an authorized student can see their private university account details.

How to protect it: Passwords, encryption, access permissions.

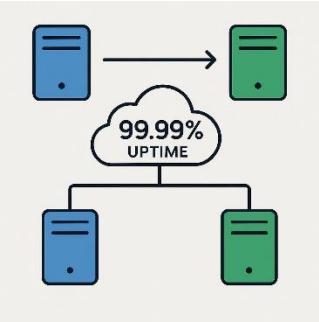


I — Integrity

Definition: Ensures that information remains accurate and is not changed without authorization.

Example: Nobody can secretly change a student's marks from 65 to 95.

How to protect it: Hashing, digital signatures, permissions and audit logs.



A — Availability

Definition: Ensures that information and systems are accessible to authorized users when needed.

Example: Students can access their results portal when results are announced.

How to protect it: Backups, redundant servers, maintenance and DDoS protection.

Easy trick to remember:

- Confidentiality = Keep it secret.
- Integrity = Keep it correct.
- Availability = Keep it accessible.

4. AAA Security Framework — Three A's

AAA stands for Authentication, Authorization, and Accounting.

1. Authentication — Who are you?

Verifies a user's identity.

Example: Logging into a banking app with a password and OTP.

2. Authorization — What can you do?

Determines which resources a user can access.

Example: A student can view marks, but only an authorized teacher can edit them.

3. Accounting — What did you do?

Records and monitors user activities.

Example: A banking system logs the time and details of a transaction.

5. Threat, Vulnerability, Exploit and Risk

These four terms are very important for exams.

Term	Definition	Real-world example
Threat	Something that could cause harm	A hacker trying to steal data
Vulnerability	A weakness in a system	An outdated application
Exploit	A method or code that takes advantage of a vulnerability	Using a known software flaw to gain unauthorized access
Risk	The possibility and potential impact of harm	The chance of student records being stolen because the server is outdated

Remember the relationship: A threat may exploit a vulnerability, creating risk to an organization.

6. Security Controls

Definition: Security controls are safeguards used to protect information and systems.

Types according to purpose

- Preventive: Stops an attack before it happens. Example: firewall.
- Detective: Identifies suspicious activity. Example: intrusion detection system (IDS).
- Corrective: Fixes a problem after detection. Example: removing malware and patching the exploited flaw.
- Recovery: Restores normal operations. Example: restoring data from a backup.

- Deterrent: Discourages people from attempting an attack. Example: warning signs about monitored systems.

Controls can also be classified by their nature:

- Technical: Encryption, firewalls, antivirus.
- Administrative: Security policies, training and procedures.
- Physical: Locks, security guards and access cards.

7. Other Important Security Principles

- Least Privilege: Give users only the permissions they need. Example: a cashier cannot access the shop owner's payroll records.
- Defense in Depth: Use multiple security layers. Example: firewall + MFA + encryption + backups.
- Zero Trust: Do not automatically trust a user or device; verify access requests appropriately. Example: requiring verification before accessing sensitive company files, even from inside the office network.

mcq rhne do me notes bna rhi hu r next

Topic 2: Security Attacks & Malware

1. What is a Security Attack?

Definition: A security attack is an attempt to access, damage, steal, or disrupt information or computer systems without proper authorization.

Real-world example: Someone tries to break into a university database to steal students' personal information.

2. Types of Security Attacks

A. Passive Attack

Definition: An attacker secretly observes or monitors information without changing the data.

Types:

- **Eavesdropping:** Secretly listening to communications.
- **Traffic Analysis:** Studying communication patterns to gather information.

Example: An attacker monitors unsecured public Wi-Fi traffic to learn which websites a user visits.

B. Active Attack

Definition: An attacker changes data, injects malicious information, or disrupts a system.

Types:

- **Masquerade:** Pretending to be an authorized user.
- **Replay Attack:** Capturing and retransmitting previously valid data.
- **Message Modification:** Changing information during transmission.
- **Denial of Service (DoS):** Making a service unavailable.

Example: An attacker modifies a payment request or floods a website with traffic to disrupt its service.

Difference: Passive attacks observe; active attacks modify, inject, or disrupt.

3. What is Malware?

Definition: Malware (malicious software) is software designed to damage systems, steal information, spy on users, or gain unauthorized access.

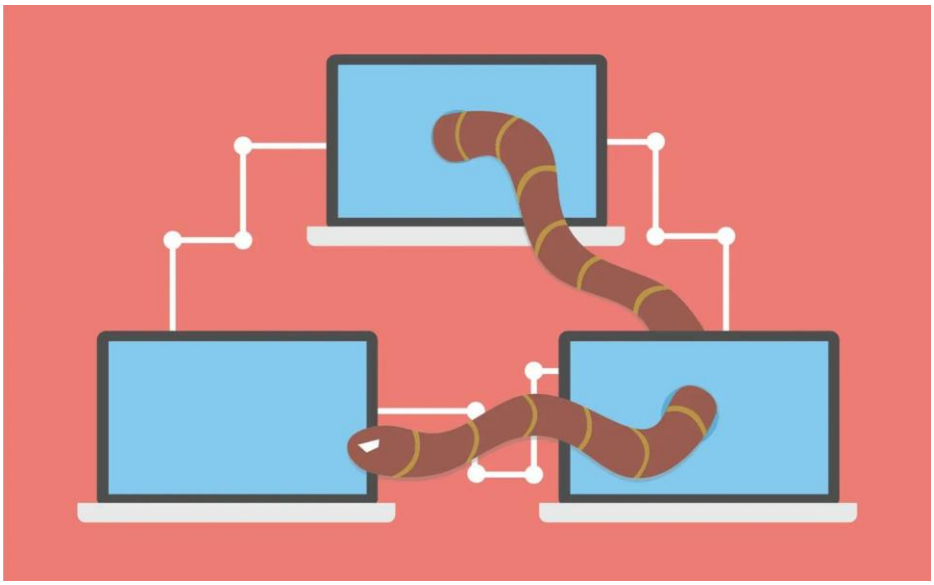
Main Types of Malware



1. Virus

Malicious code that attaches to a file or program and spreads when its host is executed.

Example: An infected file spreads malware when a user opens it.



2. Worm

Malware that can self-replicate and spread between systems, often through networks, without attaching to a host file.

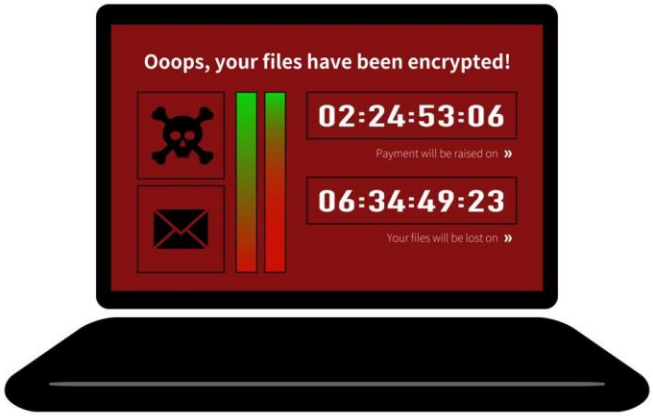
Example: A worm exploits vulnerable computers and spreads across an office network.



3. Trojan Horse

Malware disguised as legitimate or useful software.

Example: A fake game installer secretly installs malicious software.



4. Ransomware

Malware that encrypts or blocks access to data and demands payment.

Example: A hospital's files become inaccessible and a ransom message appears.



5. Spyware

Software that secretly monitors user activity or collects information.

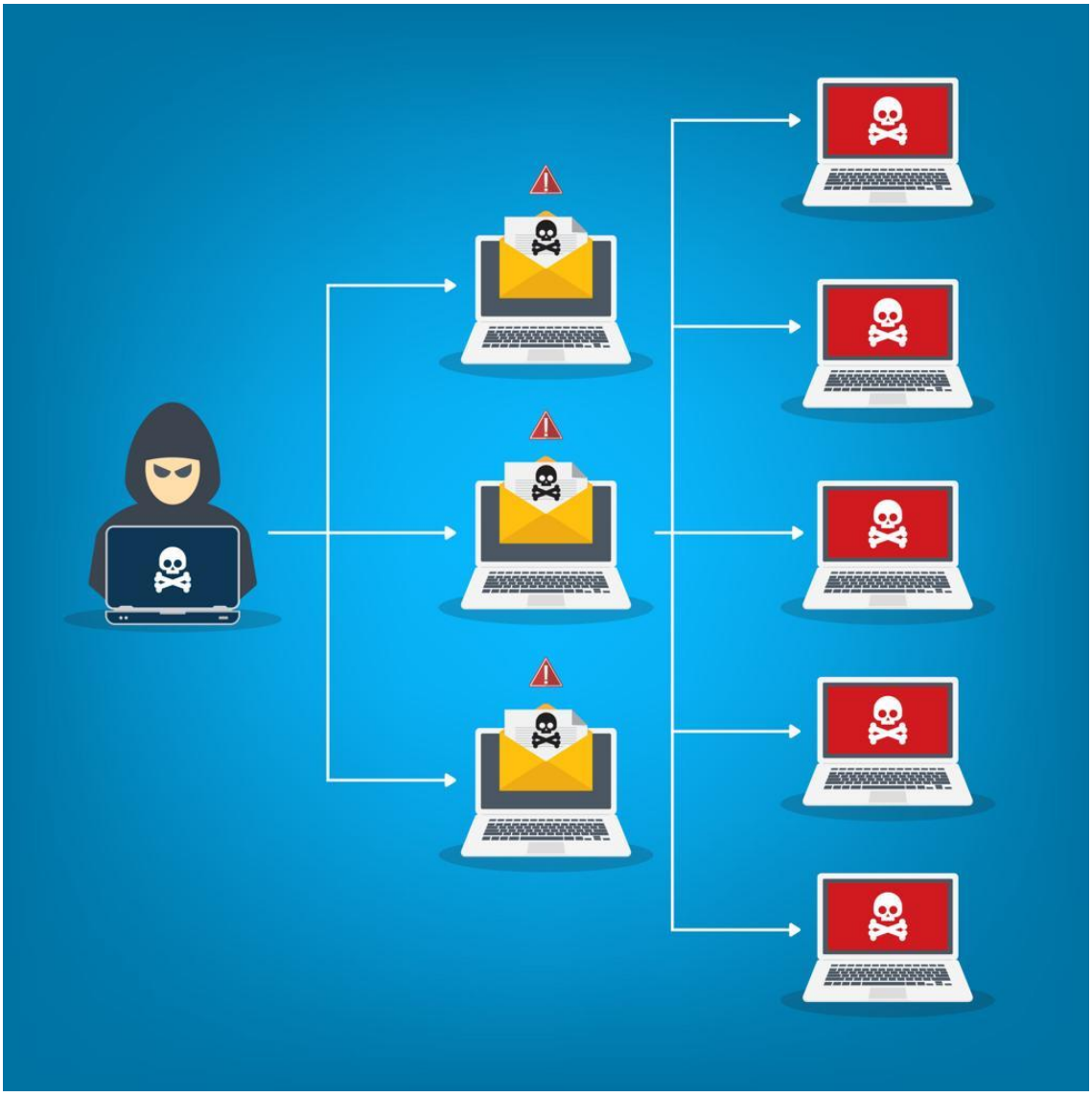
Example: Malicious software secretly collects browsing activity.



6. Adware

Software that displays unwanted advertisements; some forms also track users or deliver harmful content.

Example: A suspicious app repeatedly displays unwanted pop-up ads.



7. Botnet

A group of compromised devices controlled remotely by an attacker.

Example: Infected computers are used together to launch a DDoS attack.

4. Common Cyber Attacks

1. Phishing: Fake messages or websites trick users into revealing sensitive information.

Example: An email pretending to be from a bank asks you to verify your password through a fake website.

2. Spear Phishing: A targeted phishing attack aimed at a specific person or organization.

Example: A student receives a fake email personalized to look like it came from their university.

3. Spoofing: Falsifying an identity or source to appear trustworthy.

Example: A caller makes their number appear to belong to a bank.

4. Social Engineering: Manipulating people into revealing information or performing unsafe actions.

Example: Someone pretends to be IT support and asks an employee for their login credentials.

5. Brute-Force Attack: Repeatedly trying possible passwords until the correct one is found.

Example: An attacker attempts many password combinations against a poorly protected account.

6. Denial of Service (DoS): Overwhelming a service so legitimate users cannot access it.

Example: A website becomes unavailable because it receives excessive malicious traffic.

7. Distributed Denial of Service (DDoS): A DoS attack launched from many devices or systems.

Example: Thousands of compromised devices flood an online store, making it unavailable.

8. Man-in-the-Middle (MITM): An attacker intercepts or potentially alters communication between two parties.

Example: An attacker exploits an insecure network to intercept data exchanged between a user and a service.

5. How to Prevent These Attacks

- Use updated antivirus or endpoint protection.
- Keep operating systems and applications updated.
- Use strong, unique passwords and multi-factor authentication.
- Avoid suspicious links, attachments and unknown downloads.
- Use HTTPS websites and trusted networks.
- Keep offline or otherwise protected backups.
- Use firewalls and monitor suspicious network activity.
- Never share passwords or OTPs with unverified people.

Topic 3: Cryptography 🔐

1. What is Cryptography?

Definition: Cryptography is the technique of protecting information by converting it into a form that unauthorized people cannot understand.

Real-world example: When you use a banking app, cryptography helps protect your financial information while it travels between your phone and the bank's server.

2. Basic Terms

Plaintext

Original, readable information.

Example: `HELLO`

Ciphertext

Information transformed into an encrypted form.

Example: `KHOOR` using a Caesar cipher with a shift of 3.

Encryption

Converts plaintext into ciphertext using a cipher and key.

Example: Encrypting a confidential file.

Decryption

Converts ciphertext back into readable plaintext using the appropriate key.

Example: The authorized recipient opens the encrypted file.

3. Types of Encryption

A. Symmetric Encryption

Definition: Uses the same secret key for encryption and decryption.

Examples: AES, DES, 3DES.

Real-world example: A company encrypts files on its computers using AES. The authorized system uses the same secret key to decrypt them.

Advantage: Fast and suitable for large amounts of data.

Disadvantage: The secret key must be shared or distributed securely.

B. Asymmetric Encryption

Definition: Uses a pair of mathematically related keys: a public key and a private key.

- Public key: Can be shared with others.
- Private key: Must be kept secret by its owner.

Examples: RSA and elliptic-curve cryptography (ECC).

Real-world example: In a suitable public-key encryption scheme, someone encrypts a message using the recipient's public key, and the recipient decrypts it with their private key.

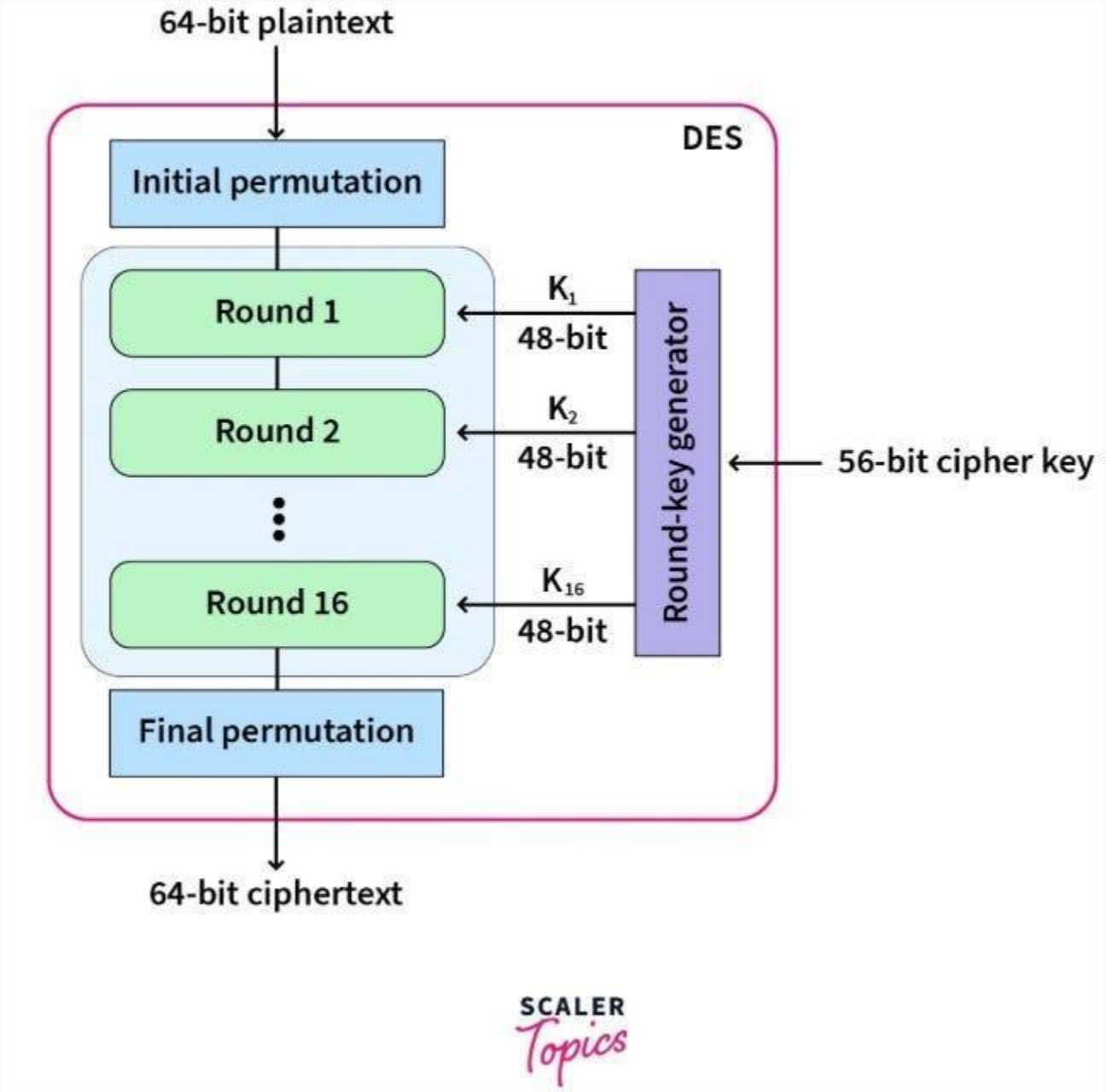
Advantage: Helps solve key-distribution problems and supports digital signatures.

Disadvantage: Generally slower than symmetric encryption.

Symmetric vs Asymmetric Encryption

Symmetric	Asymmetric
One shared secret key	Public and private key pair
Generally faster	Generally slower
Example: AES	Example: RSA
Used for bulk data encryption	Used for key establishment, encryption in suitable schemes and digital signatures

4. Important Encryption Algorithms



DES — Data Encryption Standard

A symmetric block cipher that uses a 56-bit effective key.

Example: Historically used to encrypt sensitive computer data.

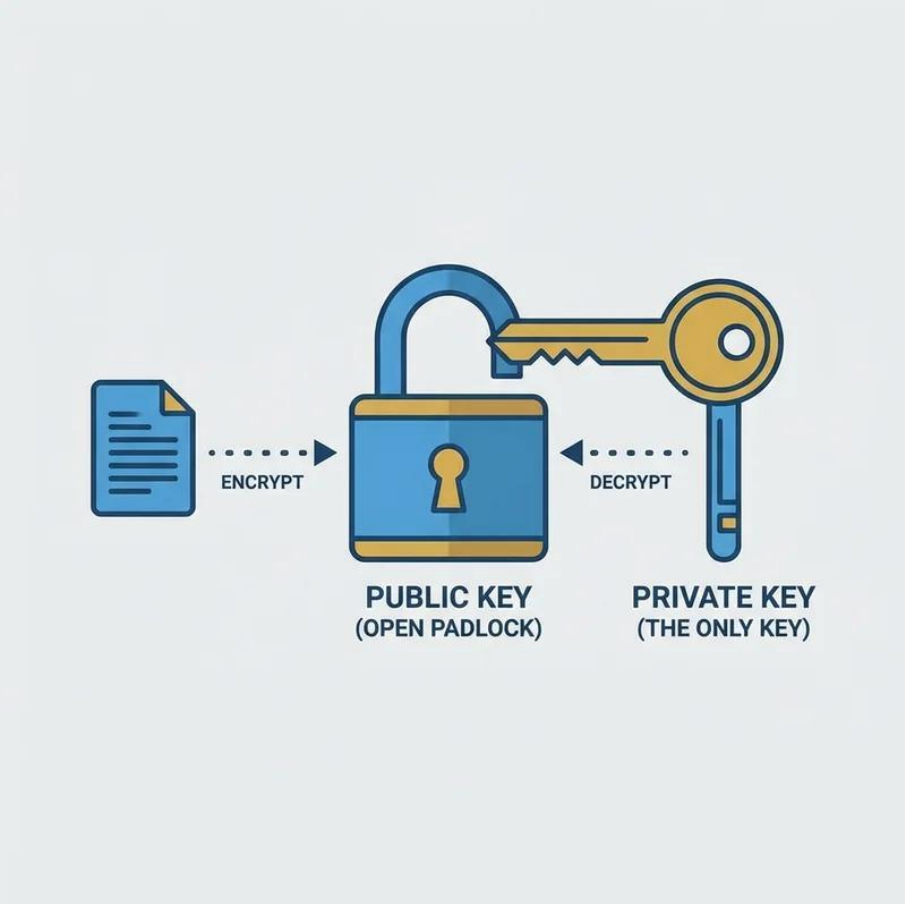
Important: DES is insecure against modern brute-force attacks and should not be used for new systems.



AES — Advanced Encryption Standard

A symmetric block cipher with 128-bit blocks and key sizes of 128, 192 or 256 bits.

Example: Modern systems use AES to protect files, storage and network data.



RSA — Rivest–Shamir–Adleman

An asymmetric cryptographic algorithm based on the difficulty of factoring large integers.

Example: RSA can be used for digital signatures and, in appropriate schemes, encryption or key transport.

5. Hashing

Definition: Hashing converts input data into a fixed-length digest using a hash function. It is designed to be one-way, rather than reversible like encryption.

Examples: SHA-256 and SHA-3.

Real-world example: Software publishers provide a SHA-256 hash so users can compare a downloaded file against the published digest to check whether the file matches.

Important points:

- Hashing does not require decryption to recover the original input.

- A small change in input should produce a different digest.
- Hashing is used for integrity checking and digital signatures.
- Passwords should be stored using dedicated password-hashing algorithms such as Argon2id, bcrypt or scrypt, preferably with unique salts—not plain SHA-256 alone.

6. Digital Signature

Definition: A digital signature is a cryptographic mechanism used to verify the origin and integrity of digital information and support non-repudiation.

How it works:

1. The sender creates a signature using their private key.
2. The recipient verifies it using the corresponding public key.
3. Successful verification supports the message's authenticity and integrity.

Real-world example: A company digitally signs an electronic contract so the recipient can verify the signature and detect changes to the signed document.

Important: A digital signature does not automatically encrypt the document or keep its contents secret.

7. Digital Certificate

Definition: A digital certificate is an electronic credential that binds an identity to a public key and is issued or signed by a trusted certificate authority (CA), subject to its validation process.

Real-world example: When you visit an HTTPS banking website, its TLS certificate helps your browser verify the website's identity and establish a secure connection.

8. Public Key Infrastructure (PKI)

Definition: PKI is the collection of technologies, policies and processes used to manage public-key certificates and their trust relationships.

Main components:

- Certificate Authority (CA)
- Digital certificates
- Public and private keys
- Certificate validation and revocation

Real-world example: A browser checks a website's certificate chain to determine whether it trusts the identity presented by the website.

9. Real-World Example: How HTTPS Uses Cryptography

When you log into your banking app or website:

1. Certificate validation: Your client checks the server's identity.
2. Key establishment: The client and server establish shared session keys using a secure protocol.
3. Symmetric encryption: Session keys protect the actual communication efficiently.
4. Integrity protection: Cryptographic mechanisms detect unauthorized changes to transmitted data.

Modern HTTPS commonly uses TLS with authenticated encryption, such as AES-GCM or ChaCha20-Poly1305.

10. Quick Revision Notes

- Cryptography: Protects information using cryptographic techniques.
- Plaintext: Original readable data.
- Ciphertext: Encrypted data.
- Encryption: Plaintext → ciphertext.
- Decryption: Ciphertext → plaintext.
- Symmetric encryption: Same secret key; example AES.
- Asymmetric cryptography: Public/private key pair; example RSA.
- Hashing: Produces a fixed-length digest; example SHA-256.
- Digital signature: Verifies origin and integrity.
- Digital certificate: Connects an identity with a public key.
- PKI: Manages certificates and public-key trust.

Topic 4: Authentication & Access Control 🔐

1. What is Authentication?

Definition: Authentication is the process of verifying the identity of a user, device, or system.

Real-world example: You enter your username and password to log in to your university portal. The system checks whether your credentials are valid.

Types of Authentication

- Knowledge-based: Something you know, such as a password or PIN.
- Possession-based: Something you have, such as a phone, security key, or OTP-generating device.
- Inherence-based: Something you are, such as a fingerprint or facial feature.

Example: Unlocking a phone using a password, a security key, or a fingerprint.

2. Multi-Factor Authentication (MFA)

Definition: MFA requires two or more different types of authentication factors to verify a user's identity.

Example: Logging into an email account using a password and then confirming the login with an authenticator app.

Important difference:

- 2FA: Exactly two authentication factors.
- MFA: Two or more authentication factors.

Using a password and PIN alone may not count as two factors because both are things you know.

3. What is Authorization?

Definition: Authorization determines which resources an authenticated user is permitted to access and which actions they can perform.

Real-world example: In a university portal, a student can view their marks, but an authorized teacher can enter or update marks.

Authentication vs Authorization

Authentication	Authorization
Verifies identity	Determines permissions
Happens before access is granted	Determines what access is allowed
Example: Checking a password	Example: Allowing a teacher to edit marks

4. What is Access Control?

Definition: Access control is the process of restricting access to resources according to permissions and security rules.

Main Access-Control Models



1. DAC — Discretionary Access Control

The resource owner decides who can access the resource.

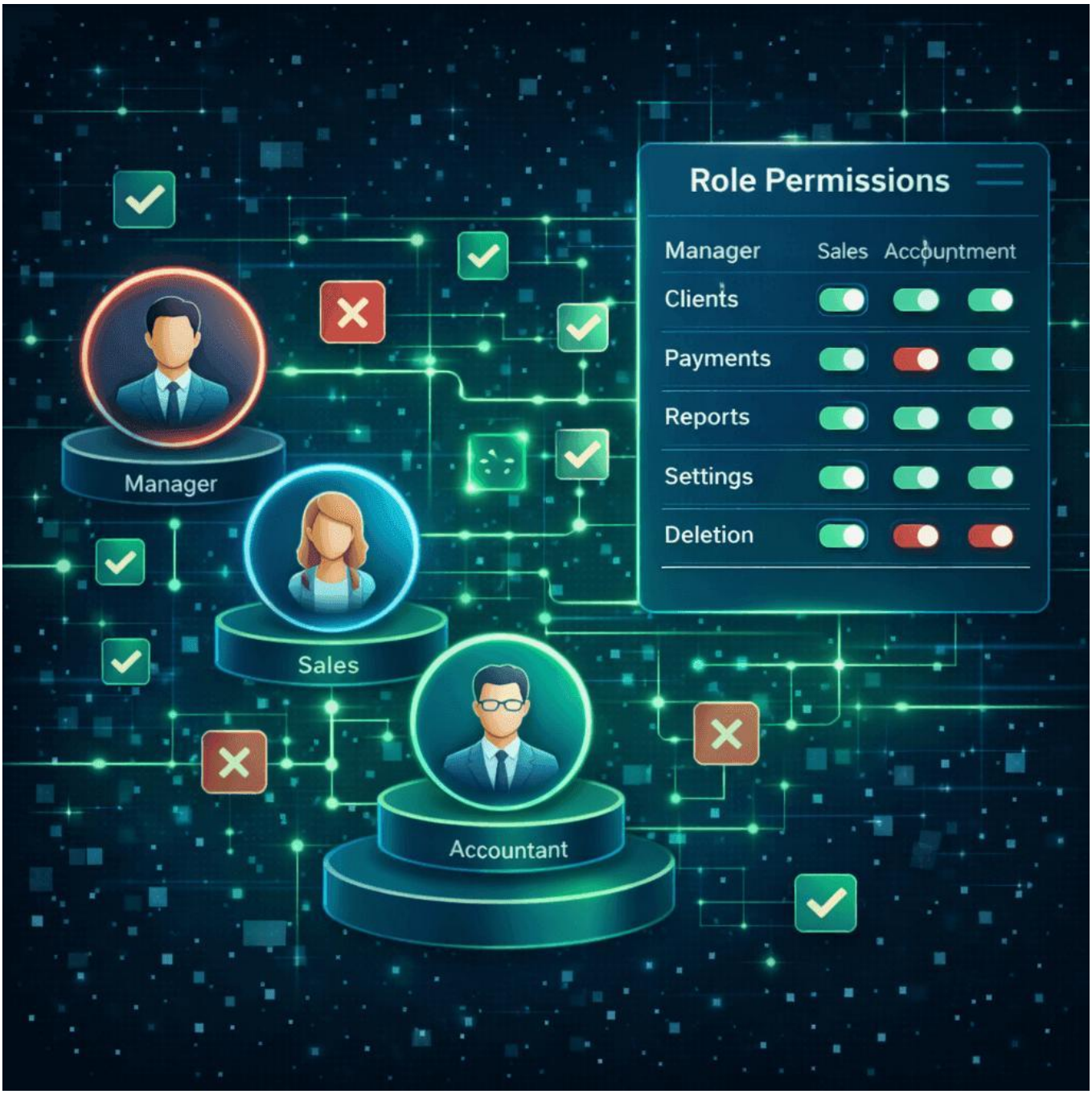
Example: A student shares a document and grants a classmate permission to view it.



2. MAC — Mandatory Access Control

Access is determined by centrally enforced security labels and user clearances.

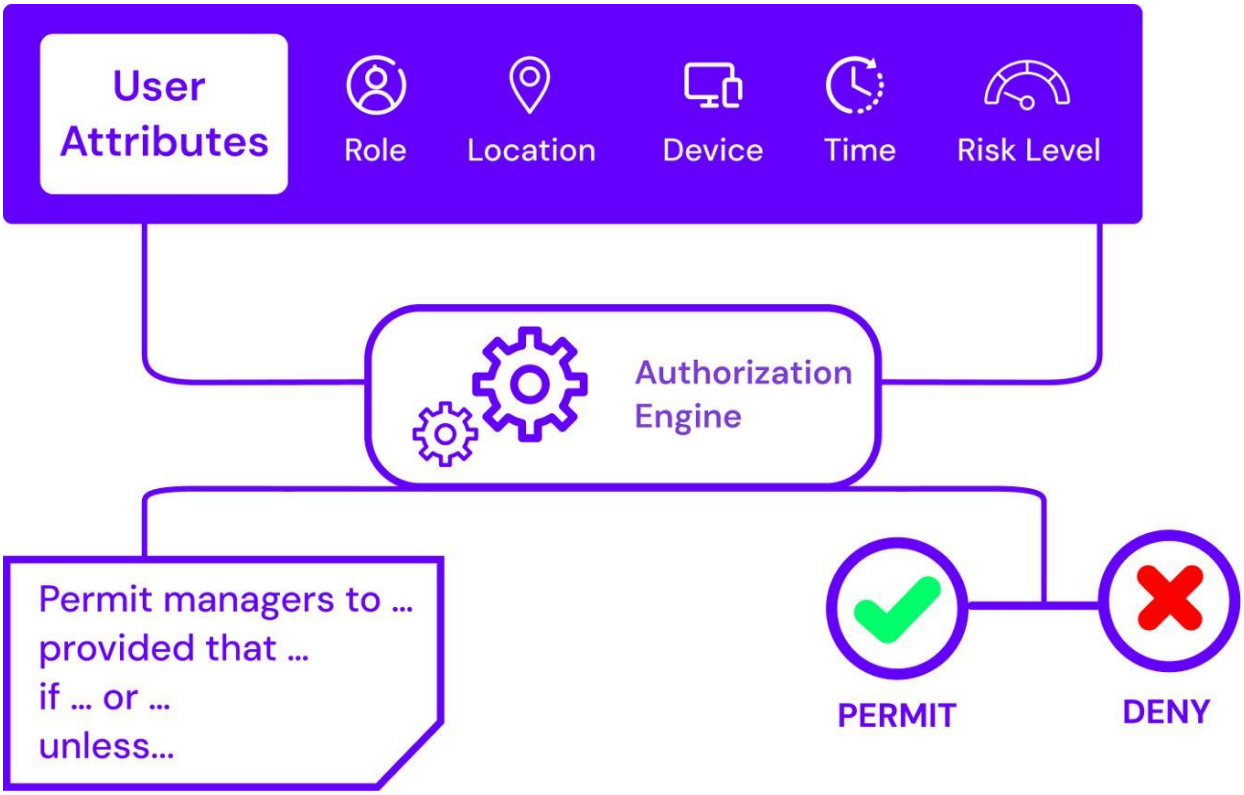
Example: In a classified government system, a user with insufficient clearance cannot access a top-secret document.



3. RBAC — Role-Based Access Control

Permissions are assigned according to a person's job role.

Example: In a hospital, doctors can access patient records, while receptionists have access to appointment information.



4. ABAC — Attribute-Based Access Control

Access depends on attributes such as user role, location, device, and time.

Example: An employee can access a sensitive system only from an approved device and network.

5. Least Privilege

Definition: The principle of least privilege means giving each user or process only the minimum permissions necessary to perform its task.

Real-world example: A shop cashier can generate bills but cannot change administrator passwords or delete the entire inventory database.

Benefit: It reduces accidental damage and limits the impact of compromised accounts.

6. Password Security

Definition: Password security involves protecting accounts by creating strong passwords and securely storing and verifying them.

Best practices:

- Use long, unique passwords for different accounts.
- Use a password manager when possible.
- Enable MFA.
- Never share passwords or OTPs.
- Avoid storing passwords in plain text.
- Services should store passwords using secure, salted password-hashing methods.

Real-world example: If one shopping website suffers a data breach, unique passwords help prevent attackers from using the same leaked password to access your email account.

7. Accounting and Auditing

Definition: Accounting records user activities, while auditing examines records to check compliance, investigate incidents, and identify suspicious behavior.

Real-world example: A banking system records who transferred money, when the transfer occurred, and whether it succeeded.

This completes the AAA framework:

- Authentication: Who are you?
- Authorization: What are you allowed to do?
- Accounting: What did you do?

8. Quick Revision

- Authentication verifies identity.
- Authorization determines permissions.
- MFA uses multiple types of authentication factors.
- DAC: Resource owner controls access.
- MAC: Centrally enforced security labels and clearances.
- RBAC: Access based on job roles.
- ABAC: Access based on attributes and rules.
- Least privilege: Minimum necessary permissions.
- Accounting and auditing: Record and examine activities.

Topic 5: Network Security 🌐

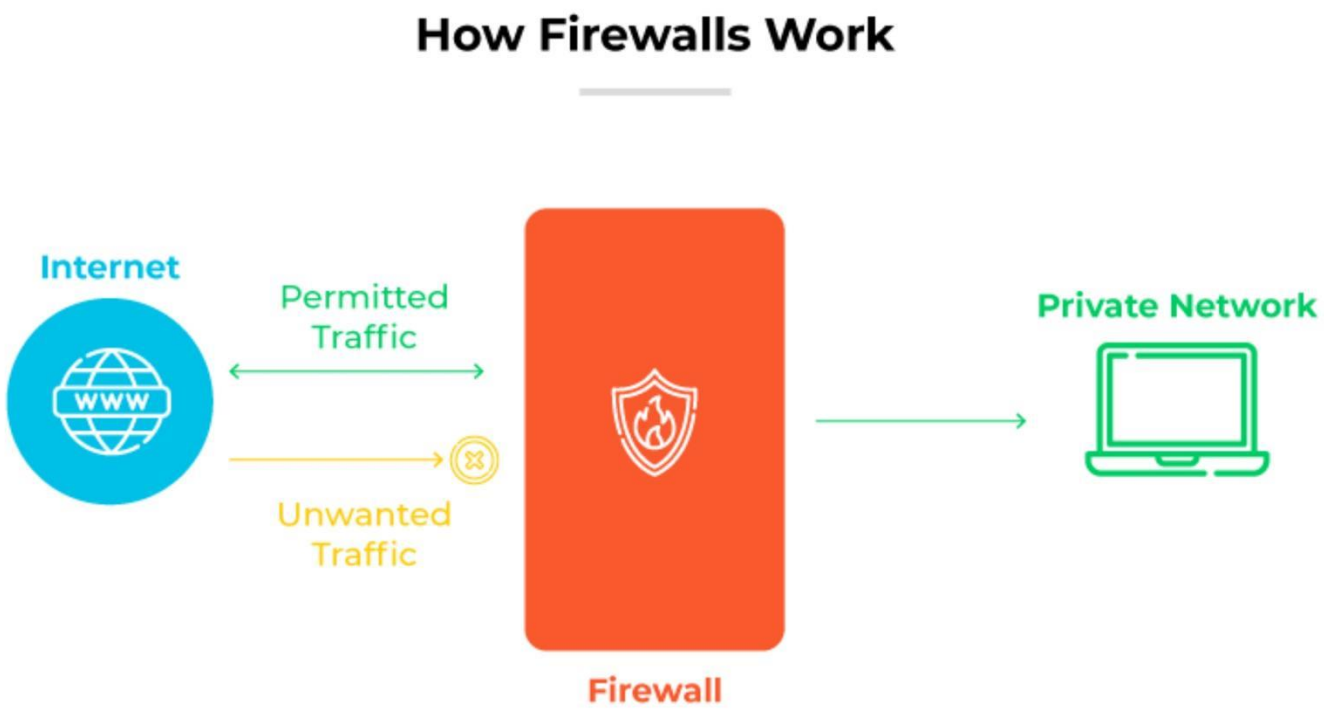
1. What is Network Security?

Definition: Network security is the practice of protecting computer networks and data from unauthorized access, attacks, misuse, and damage.

Real-world example: A university protects its Wi-Fi network so unauthorized people cannot access its internal systems.

2. Firewall

Definition: A firewall monitors and filters incoming and outgoing network traffic according to predefined security rules.



paloaltonetworks.co.uk

Types:

- Hardware firewall: A physical device that protects a network.
- Software firewall: Software that filters network traffic on a computer or server.
- Next-generation firewall (NGFW): Provides advanced inspection and application-aware filtering.

Example: A firewall blocks unauthorized connections to a company's internal network.

3. IDS vs IPS

- IDS (Intrusion Detection System): Detects suspicious activity and generates alerts.
- IPS (Intrusion Prevention System): Detects suspicious activity and can automatically block it.

IDS	IPS
Detects and alerts	Detects and blocks
Mainly monitors traffic	Can act on traffic
Example: Alerts about a port scan	Example: Blocks malicious traffic

4. VPN (Virtual Private Network)

Definition: A VPN creates an encrypted tunnel between a device and a VPN endpoint over a network.

Example: An employee uses a company VPN to securely access internal office resources while working from home.

Benefits: Protects traffic over untrusted networks and supports secure remote access.

Note: A VPN does not automatically make every website or activity safe.

5. HTTPS and TLS

HTTPS: The secure version of HTTP used to protect communication between a browser and a website.

TLS (Transport Layer Security): A protocol that provides encryption, integrity, and authentication for network communications.

Example: When you log in to online banking through HTTPS, TLS helps protect your credentials while they travel between your browser and the bank.

- HTTP: Does not provide TLS protection by itself.
- HTTPS: Uses HTTP over TLS.

6. SSH (Secure Shell)

Definition: SSH is a protocol used to securely access and manage remote computers over a network.

Example: A system administrator uses SSH to manage a Linux server remotely.

Common port: TCP 22.

SSH provides encrypted communication and supports password or public-key authentication.

7. Wi-Fi Security

Wi-Fi security protects wireless networks from unauthorized access and data interception.

Common security standards:

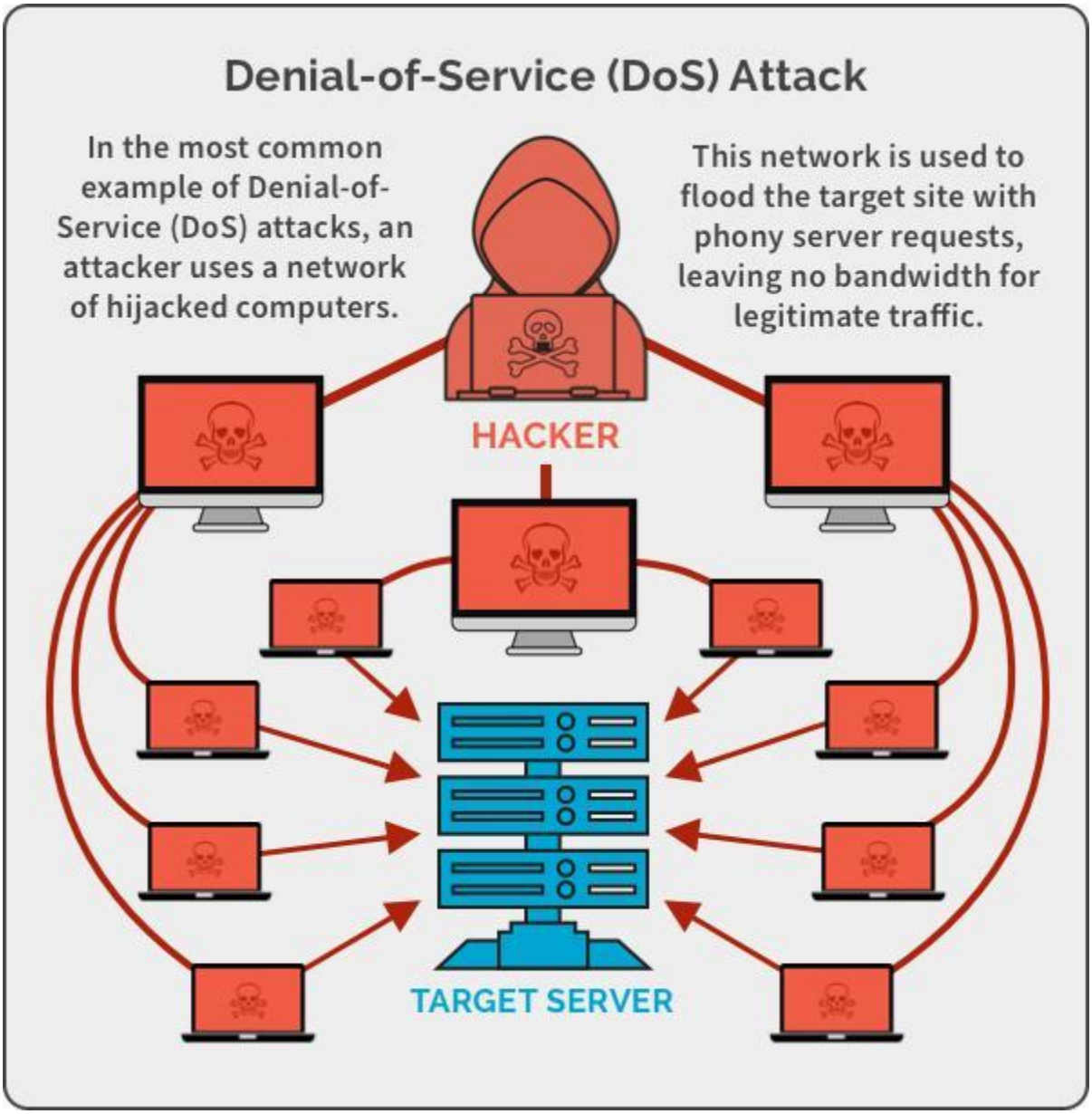
- WEP: Outdated and insecure.
- WPA2: Common security standard using AES-based protection.
- WPA3: Newer standard with improved security features.

Best practices:

- Use WPA2-AES or WPA3.
- Set a strong, unique Wi-Fi password.
- Change the router's default administrator password.
- Update router firmware.
- Disable WPS if it is not needed.

Example: A home router configured with WPA3 and a strong password is better protected against unauthorized connections than one using WEP.

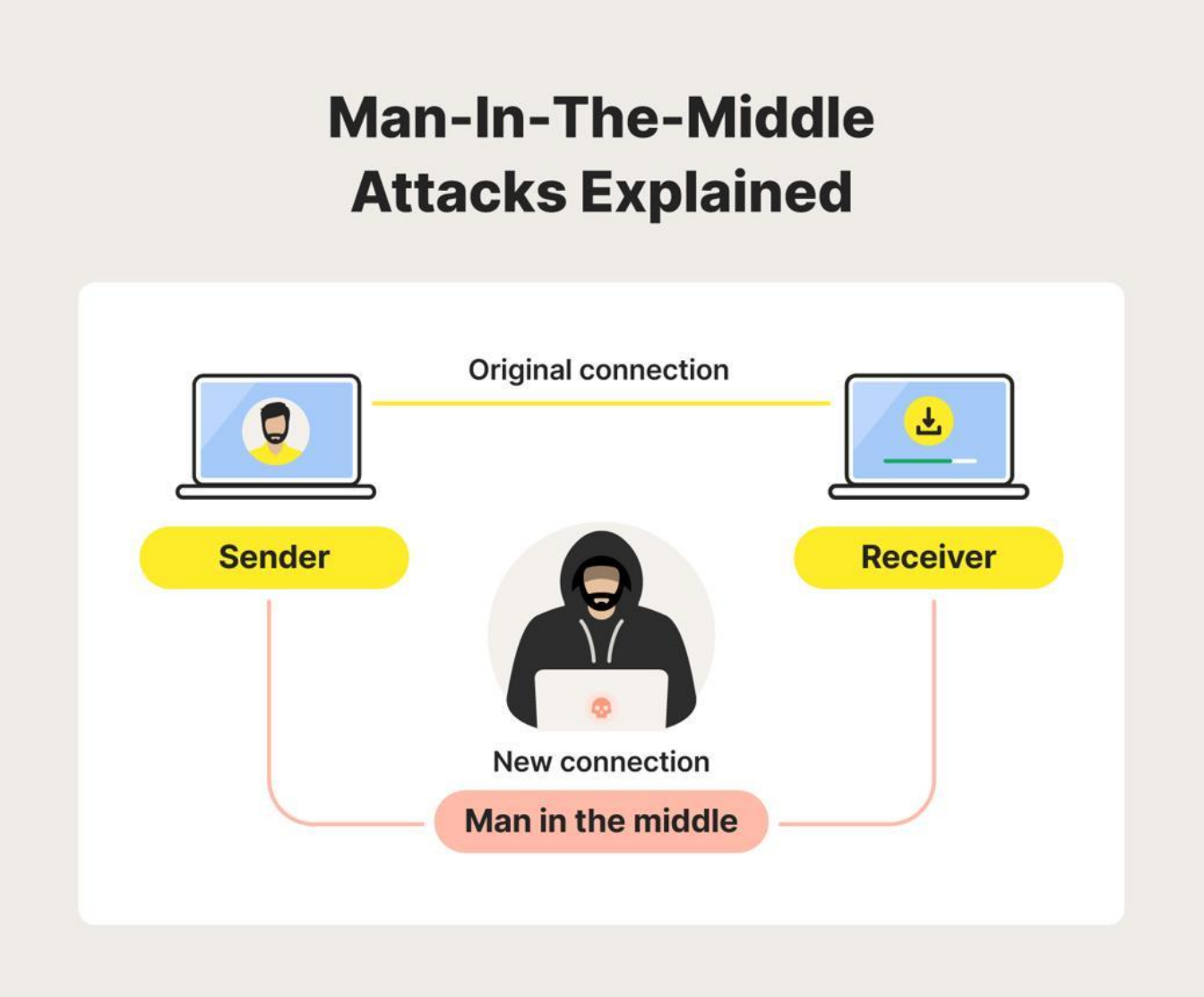
8. Common Network Attacks



1. DoS / DDoS

Flooding a service with traffic to make it unavailable. DDoS uses multiple systems.

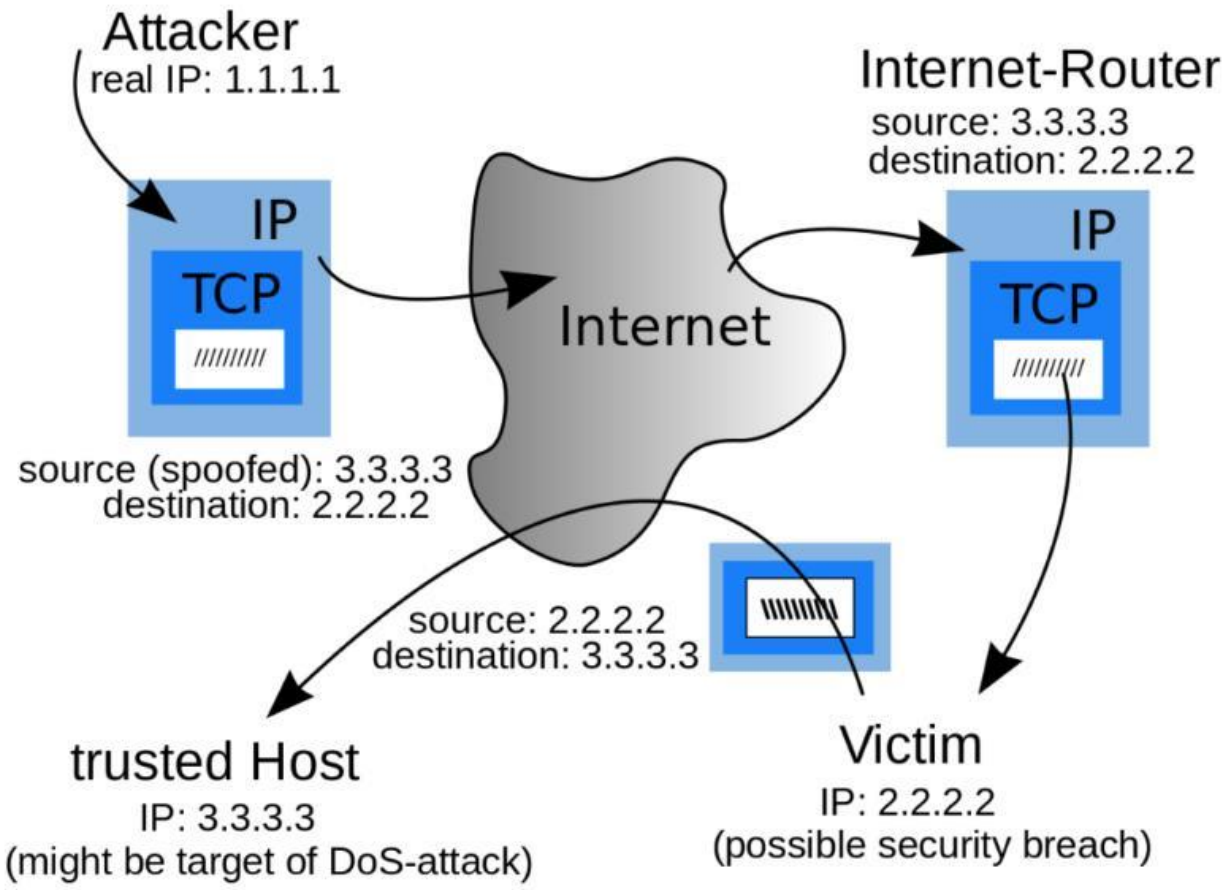
Example: An online store becomes unavailable because of malicious traffic.



2. Man-in-the-Middle (MITM)

An attacker intercepts communication between two parties and may alter it.

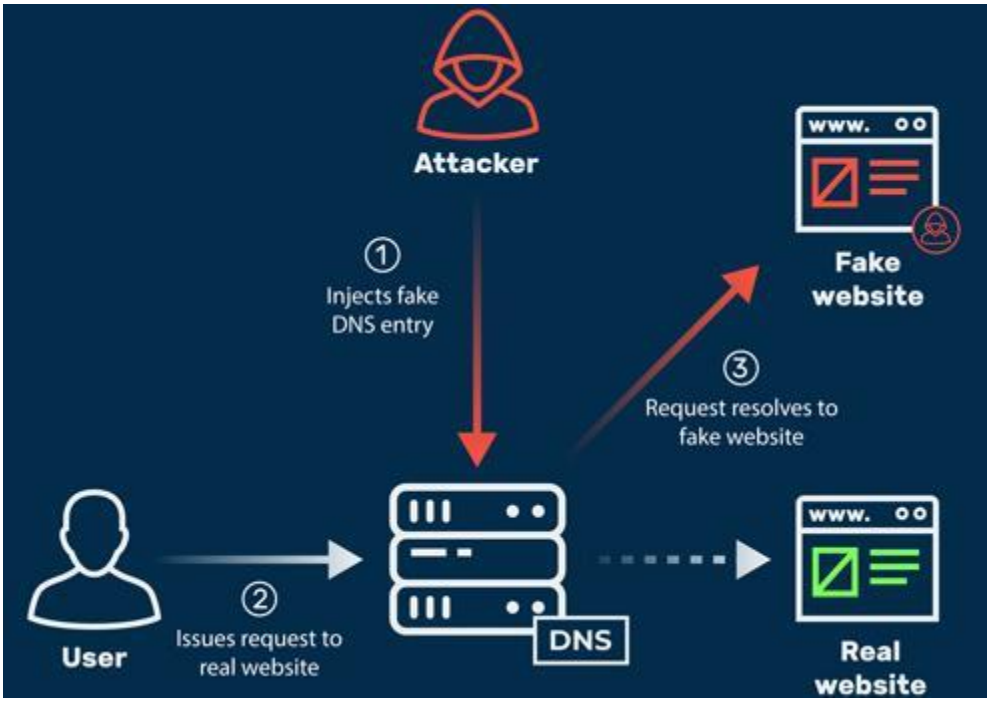
Example: An attacker on a compromised network attempts to intercept unprotected communication.



3. IP Spoofing

An attacker forges the source IP address in network packets.

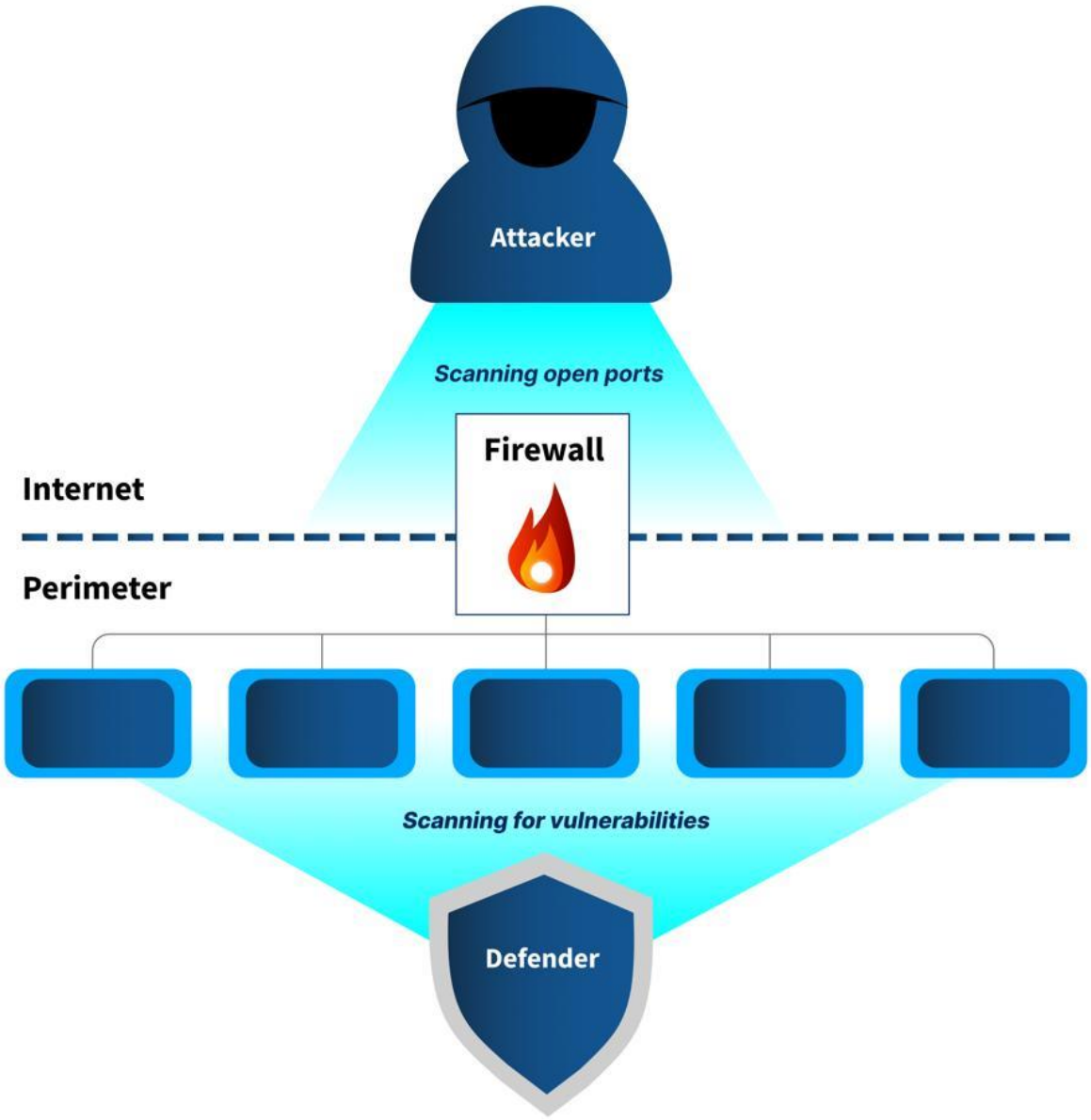
Example: Spoofed packets are used in an attempt to hide their source or support a DDoS attack.



4. DNS Spoofing

False DNS information directs a user toward an incorrect or malicious destination.

Example: A user is redirected to a fake banking website.



5. Port Scanning

Checking a system's ports to identify potentially accessible services.

Example: An attacker searches for exposed services that may have weaknesses.

9. Network Security Best Practices

- Configure firewalls properly.
- Use IDS/IPS to detect or prevent suspicious traffic.
- Encrypt communication with HTTPS/TLS and SSH.

- Secure Wi-Fi using WPA2-AES or WPA3.
- Install security updates.
- Disable unnecessary ports and services.
- Use VPNs for secure remote access when appropriate.
- Monitor network logs and maintain backups.

10. Quick Revision

- Firewall: Filters network traffic.
- IDS: Detects and alerts.
- IPS: Detects and can block.
- VPN: Creates an encrypted tunnel.
- HTTPS/TLS: Protects web communication.
- SSH: Secure remote administration.
- WPA2/WPA3: Wi-Fi security standards.
- DoS/DDoS: Makes services unavailable.
- MITM: Intercepts communication.
- DNS spoofing: Redirects users using false DNS information.

Topic 6: System & Database Security 🔐

1. What is System Security?

Definition: System security is the protection of computers, operating systems, and system resources against unauthorized access, malware, and other threats.

Real-world example: A university protects its computers using user accounts, antivirus software, and access permissions.

Main System Security Measures

- User authentication: Verify users before allowing login.
- File permissions: Control who can read, write, or execute files.
- Patching: Install security updates to fix vulnerabilities.
- Antivirus/endpoint protection: Detect and block malicious software.
- Firewall: Filter unauthorized network traffic.
- Backups: Restore data after accidental deletion or an attack.

2. Operating System (OS) Security

OS security protects system files, processes, memory, and user accounts.

Important practices:

- Use standard accounts for everyday work.
- Give administrator privileges only when necessary.
- Keep the OS and applications updated.
- Enable screen locks and strong authentication.
- Disable unnecessary services.
- Review system logs for suspicious activity.

Example: On Linux, normal users cannot modify protected system files without sufficient permissions.

3. File Permissions

File permissions determine what users can do with files and directories.

In Linux, the three basic permissions are:

- Read (`r`): View file contents.
- Write (`w`): Modify a file.
- Execute (`x`): Run a file as a program.

Permissions apply to three categories:

- User (`u`): File owner.
- Group (`g`): Users in the assigned group.
- Others (`o`): Everyone else.

Example command:

```
chmod 640 report.txt
```

Meaning:

- Owner: read and write (`6`)
- Group: read only (`4`)
- Others: no permissions (`0`)

Real-world example: A teacher's private marks file can be restricted so only the teacher and an authorized group can read it.

4. Security Patching

Definition: Patching is the process of installing software updates that fix security vulnerabilities, bugs, or other problems.

Example: Updating an outdated browser can fix a vulnerability that attackers might exploit.

Why it matters: Unpatched systems may remain vulnerable even when antivirus software is installed.

5. What is Database Security?

Definition: Database security protects stored information from unauthorized access, disclosure, modification, or deletion.

Real-world example: A hospital restricts access to patient records so only authorized employees can view or update them.

Main Database Security Controls

- Authentication: Verify database users.
- Authorization: Assign appropriate database permissions.
- Encryption: Protect sensitive data.
- Auditing: Record database activities.
- Backup and recovery: Restore data after loss or corruption.
- Input validation: Check incoming data before processing it.

6. SQL Injection

Definition: SQL injection is an attack in which malicious SQL input changes the meaning of a database query because user input is handled unsafely.

Example: A login form that directly combines user input with an SQL query may allow an attacker to bypass authentication or access unauthorized records.

Prevention:

- Use parameterized queries or prepared statements.
- Validate input appropriately.
- Apply least-privilege permissions to database accounts.
- Avoid displaying detailed database errors to users.
- Keep database software updated.

A parameterized-query example in SQL-style pseudocode:

```
SELECT * FROM Users
WHERE username = ? AND password_hash = ?;
```

The `?` placeholders represent parameters supplied separately from the SQL statement. This helps prevent input from being interpreted as SQL code. Passwords should be securely hashed and verified rather than stored in plain text.

7. Database Backup and Recovery

Definition: A backup is a separate copy of data used to restore information after loss, corruption, or an attack.

Types of backup:

- Full backup: Copies all selected data.
- Incremental backup: Copies changes since the last backup.
- Differential backup: Copies changes since the last full backup.

Example: If ransomware damages a company's database, a clean backup can help restore its records.

Best practice: Keep protected backups, maintain an offline or isolated copy, and test restoration regularly.

8. Database Auditing

Definition: Database auditing records and reviews activities to help identify unauthorized access and suspicious changes.

Example: An audit log records which account accessed student records and when a user's marks were modified.

Auditing supports accountability, investigation, and compliance.

9. Quick Revision

- System security: Protects computers and operating systems.
- File permissions: Control reading, writing, and execution.
- Patching: Fixes known software vulnerabilities.
- Database security: Protects stored data.
- SQL injection: Exploits unsafe handling of SQL input.
- Parameterized queries: Help prevent SQL injection.
- Backup: Provides a copy for restoration.
- Auditing: Records and reviews activities.
- Least privilege: Gives users only the permissions they need.

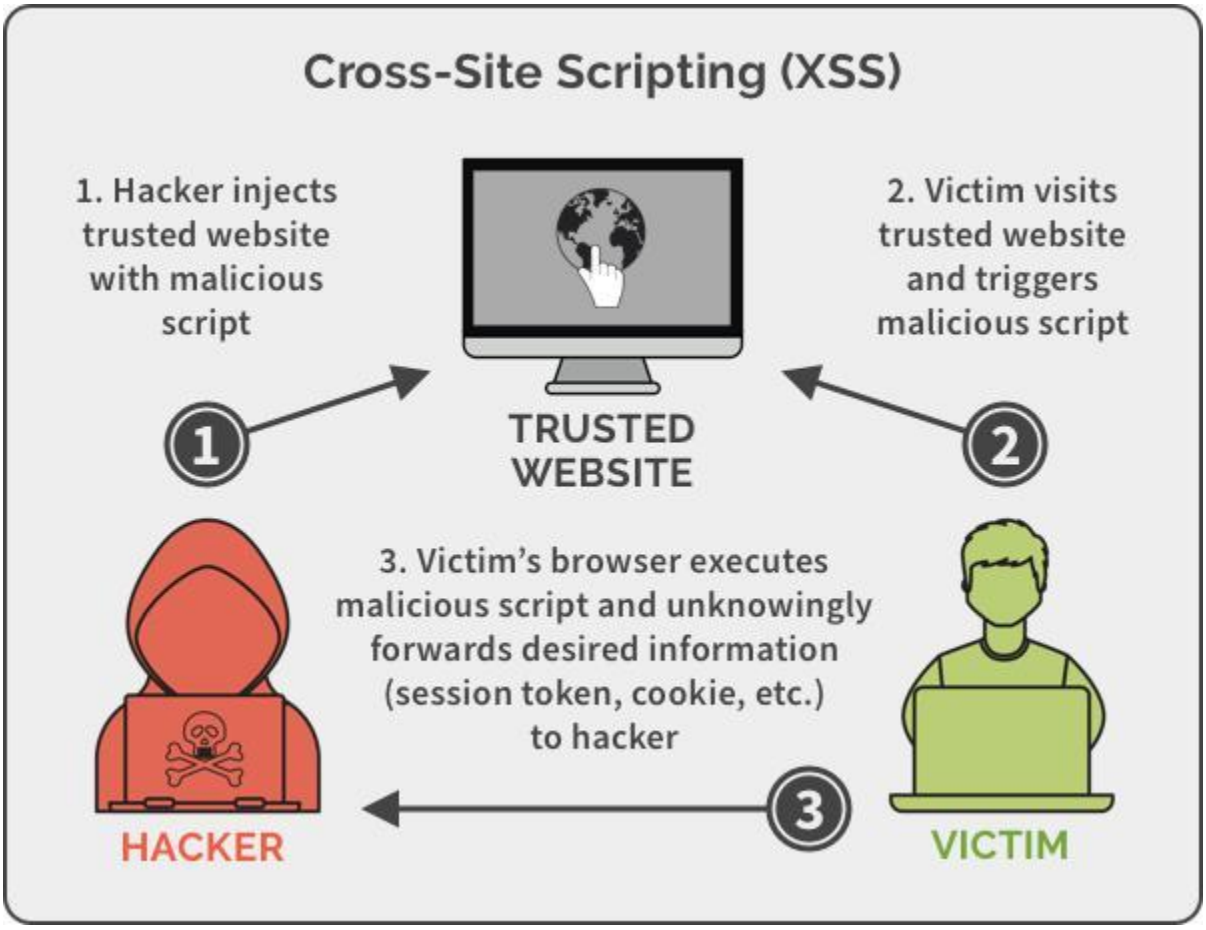
Topic 7: Web & Application Security 🌐

1. What is Web Security?

Definition: Web security is the practice of protecting websites, web applications, and their data from unauthorized access, attacks, and misuse.

Real-world example: An online shopping website protects customer accounts, payment information, and orders against attackers.

2. Common Web Attacks

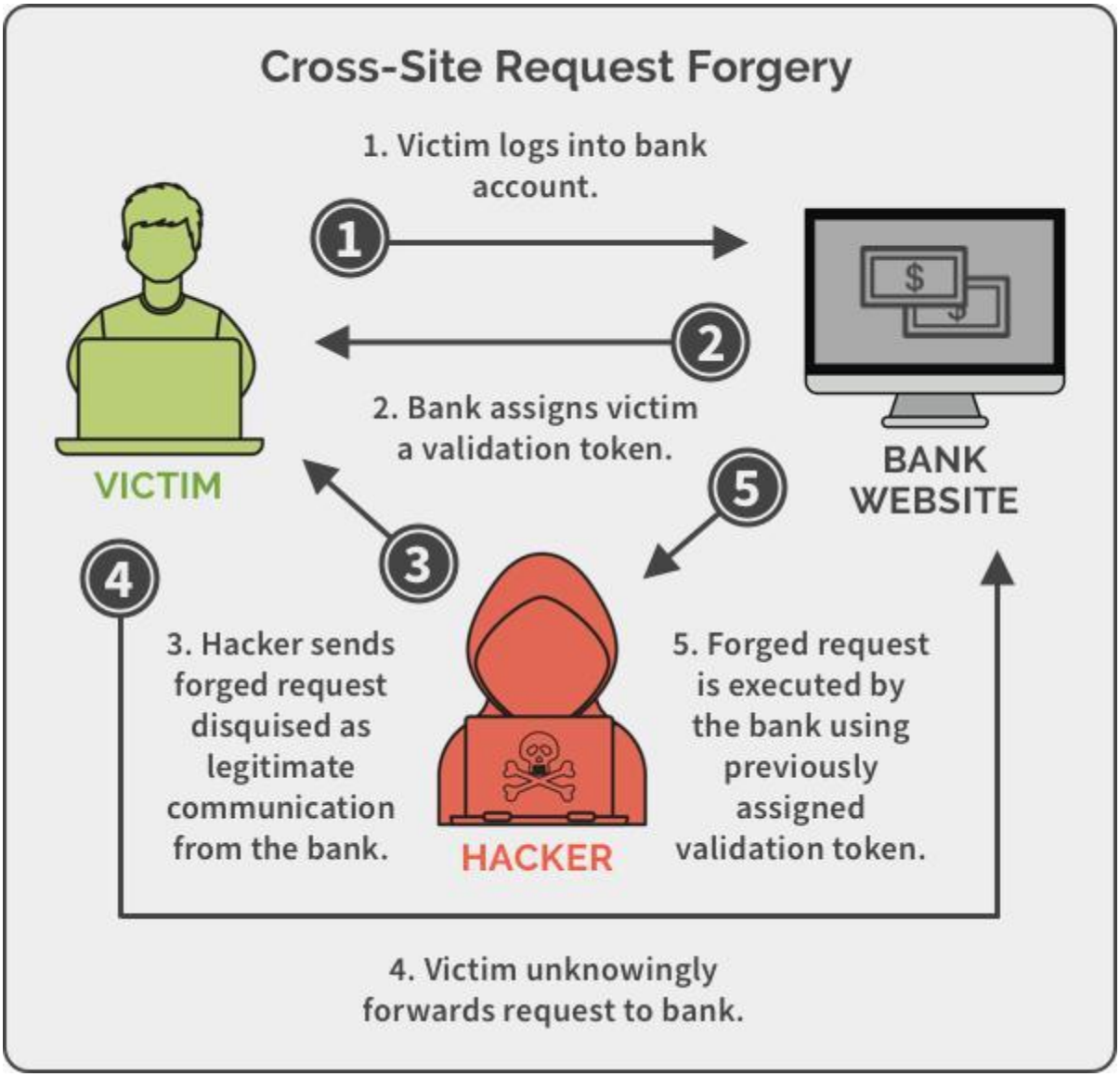


1. Cross-Site Scripting (XSS)

An attacker injects malicious script into a webpage that runs in another user's browser.

Example: A vulnerable comment section displays an attacker's script to visitors.

Prevention: Encode output, sanitize HTML where appropriate, and use Content Security Policy (CSP).

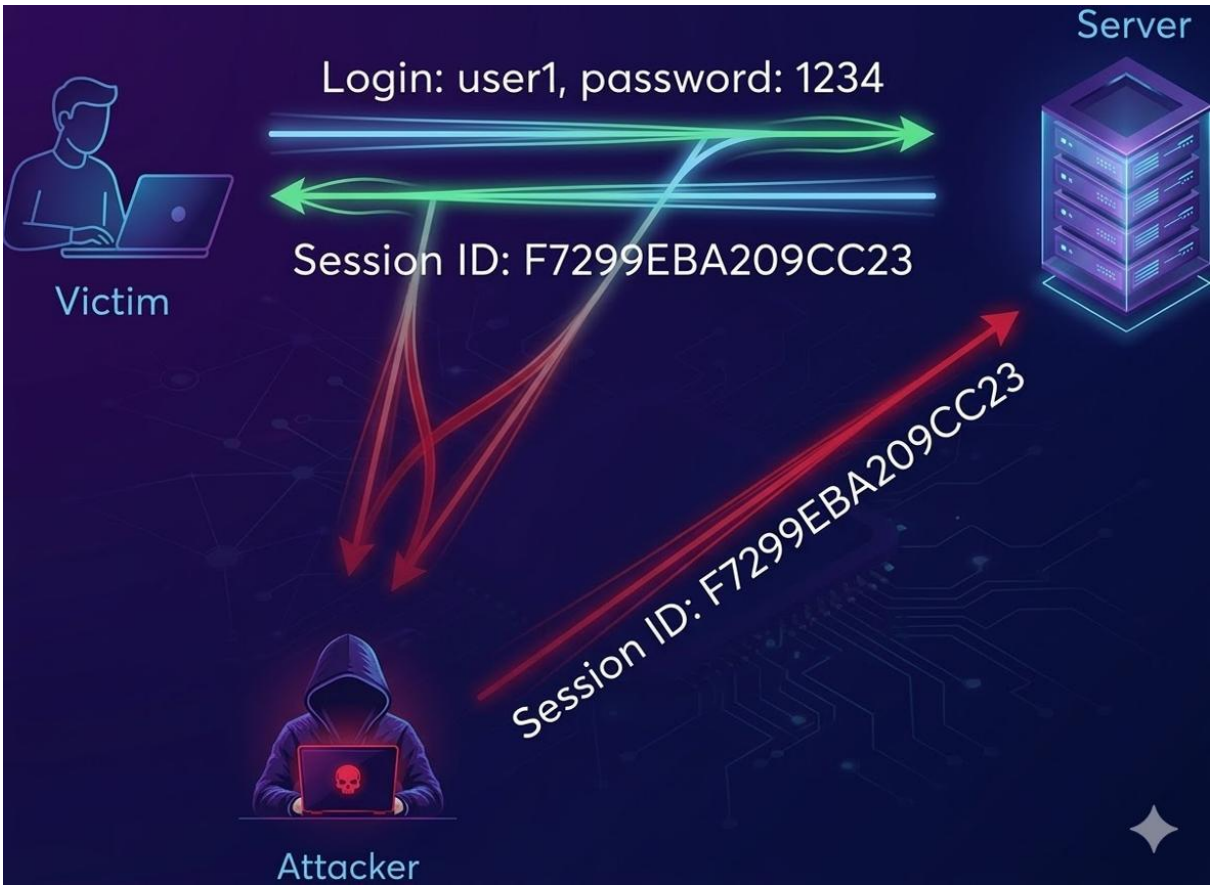


2. Cross-Site Request Forgery (CSRF)

Tricks an authenticated user's browser into sending an unwanted request to a website.

Example: A user who is logged into a vulnerable banking website is tricked into submitting an unauthorized request.

Prevention: Use CSRF tokens, appropriate SameSite cookie settings, and request validation.

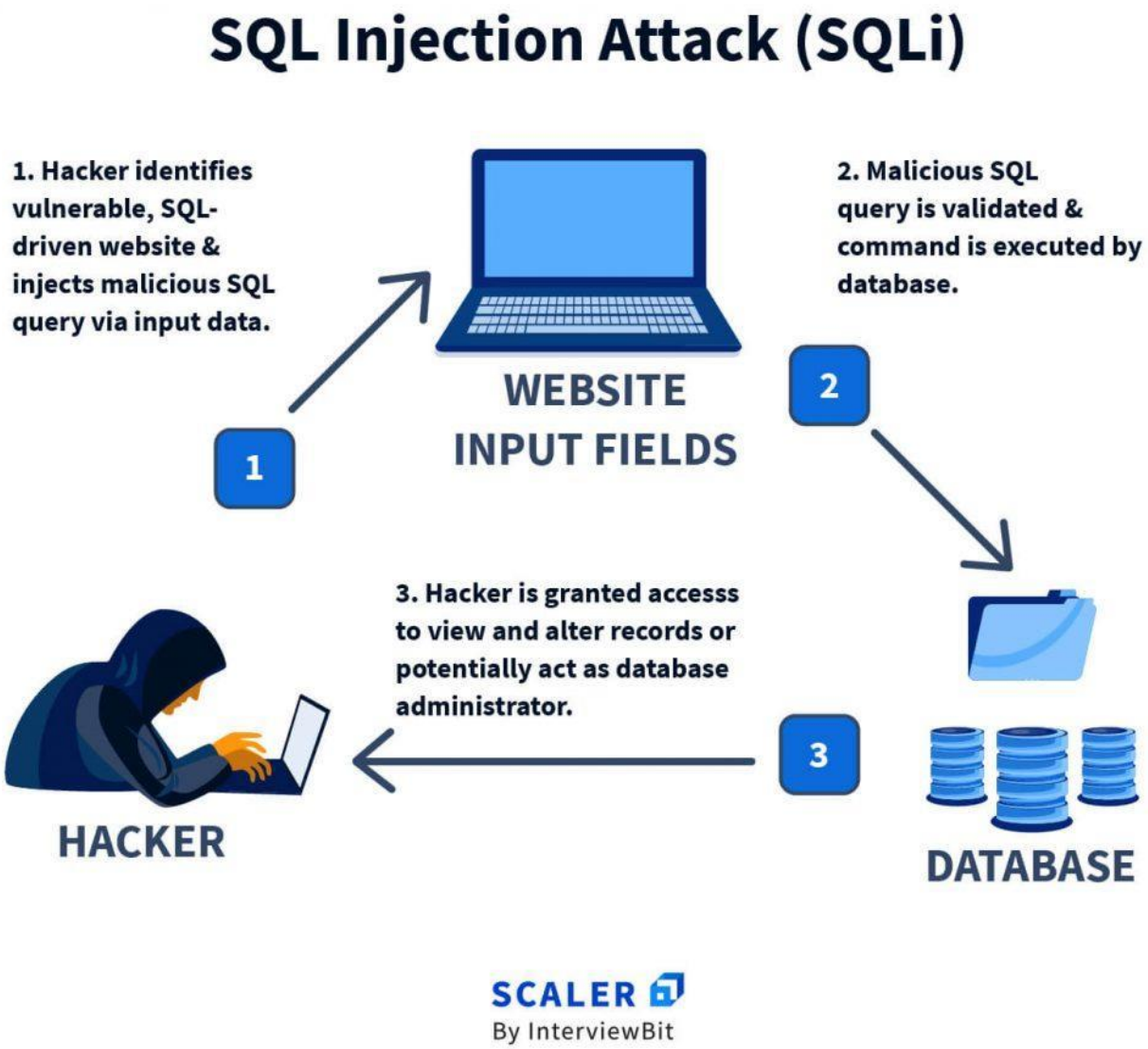


3. Session Hijacking

An attacker obtains or abuses a user's session identifier to impersonate that user.

Example: A stolen session cookie lets an attacker access a victim's account.

Prevention: Use HTTPS, secure cookie settings, session rotation, and logout or session expiration.



4. SQL Injection

Unsafe input handling allows user input to change a database query.

Example: A vulnerable login form allows an attacker to bypass authentication.

Prevention: Use parameterized queries and least-privilege database accounts.



5. Broken Access Control

An application fails to enforce proper permissions.

Example: A student changes a URL and gains access to another student's private results.

Prevention: Check authorization on the server for every protected resource and action.

3. Authentication and Session Management

Web applications must verify users and manage their logged-in sessions securely.

Important practices:

- Use strong passwords and MFA.
- Store passwords using secure password-hashing algorithms.
- Use unpredictable session identifiers.
- Set cookies with `Secure`, `HttpOnly`, and appropriate `SameSite` attributes.
- Expire sessions after inactivity and invalidate them on logout.
- Use HTTPS across the entire website.

Real-world example: A university portal automatically expires an inactive session and requires the user to log in again.

4. Secure Coding

Definition: Secure coding means writing software in a way that reduces security vulnerabilities.

Best practices:

- Validate input on the server.
- Encode output to prevent XSS.
- Use parameterized SQL queries.
- Check authorization for sensitive actions.
- Avoid hardcoding passwords and secret keys.
- Handle errors without exposing sensitive information.
- Keep frameworks and libraries updated.
- Test applications before deployment.

Example: An e-commerce application checks the user's permissions on the server before allowing an order to be cancelled.

5. Cookies

Definition: Cookies are small pieces of data stored by a browser and sent to a website according to their scope and settings.

Uses: Maintaining login sessions, storing preferences, and remembering shopping-cart information.

Security: Sensitive session cookies should use HTTPS and appropriate security attributes. Avoid storing passwords or sensitive secrets in ordinary cookies.

Example: A shopping website uses a session cookie to remember a user's login while they browse different pages.

6. HTTPS and Web Certificates

HTTPS protects communication between a browser and a website using TLS.

It provides:

- Confidentiality: Helps prevent others from reading transmitted data.
- Integrity: Helps detect unauthorized changes in transit.
- Authentication: Helps the browser verify the website's identity through its certificate.

Example: A browser connects to an online store using HTTPS to protect login details and order information in transit.

Remember: HTTPS does not guarantee that a website itself is trustworthy.

7. OWASP Top 10

OWASP stands for Open Worldwide Application Security Project. It publishes guidance about major web application security risks.

Common risk categories include:

- Broken Access Control
- Cryptographic Failures
- Injection
- Insecure Design
- Security Misconfiguration
- Vulnerable and Outdated Components
- Identification and Authentication Failures
- Software and Data Integrity Failures
- Security Logging and Monitoring Failures
- Mishandling of Exceptional Conditions

These categories help developers identify and reduce common security risks.

8. Quick Revision

- XSS: Malicious script executes in a user's browser.
- CSRF: Tricks a user's browser into sending an unwanted request.
- Session hijacking: Abuses a stolen or compromised session.
- SQL injection: Unsafe input changes a database query.
- Broken access control: Users gain access beyond their permissions.

- Secure coding: Develop software with security in mind.
- Cookies: Store small pieces of browser-related data.
- HTTPS: Protects communication using TLS.
- OWASP: Provides web application security guidance.

Topic 8: Risk Management & Security Policies

1. What is Risk Management?

Definition: Risk management is the process of identifying, assessing, and treating risks that may affect an organization's information systems and data.

Real-world example: A university identifies the risk of losing student records and creates regular backups to reduce the impact.

2. Important Risk Terms

- Asset: Anything valuable that needs protection, such as student records.
- Threat: Something that could cause harm, such as ransomware.
- Vulnerability: A weakness that can be exploited, such as outdated software.
- Risk: The possibility of loss or harm when a threat exploits a vulnerability.
- Impact: The damage caused if an incident occurs.
- Likelihood: The probability that an incident will occur.

Example: Outdated university software (vulnerability) may be exploited by an attacker (threat), potentially exposing student records (risk).

3. Risk Assessment

Definition: Risk assessment is the process of identifying risks and evaluating their likelihood and impact.

Steps:

1. Identify assets.
2. Identify threats and vulnerabilities.
3. Estimate likelihood.
4. Estimate impact.
5. Prioritize risks according to severity.

A simple risk-prioritization model is:

Risk level = Likelihood × Impact

Organizations may use low, medium, and high ratings or numerical scales.

Example: A risk of losing all student records may be rated high because the impact is severe.

4. Risk Treatment Methods



1. Risk Mitigation (Reduce)

Reduce the likelihood or impact of a risk.

Example: Install security patches and enable MFA to reduce account compromise.



2. Risk Transfer (Share)

Transfer or share some financial consequences with another party.

Example: Purchase cyber insurance to help cover certain incident-related costs.



3. Risk Avoidance

Stop the activity that creates the risk.

Example: Disable an unnecessary internet-facing service that creates unacceptable exposure.



4. Risk Acceptance

Formally accept a risk when it is within the organization's tolerance.

Example: Management accepts a minor residual risk after evaluating its cost and impact.

5. Security Policies

Definition: A security policy is a formal document that defines an organization's security rules, responsibilities, and requirements.

Purpose: To protect information, guide employees, and establish consistent security practices.

Types of Security Policies

- Password policy: Defines password and authentication requirements.
- Acceptable Use Policy (AUP): Defines acceptable use of organizational devices and networks.
- Access Control Policy: Defines who can access systems and data.
- Data Protection Policy: Defines how sensitive information must be handled.
- Incident Response Policy: Defines how security incidents must be reported and managed.

Real-world example: A company requires employees to enable MFA and report suspicious emails.

6. Security Awareness Training

Definition: Security awareness training teaches employees how to recognize threats and follow security procedures.

Common topics:

- Recognizing phishing emails.
- Protecting passwords and OTPs.
- Handling confidential data.
- Using company devices securely.
- Reporting suspicious activity.

Example: Employees learn not to open unexpected email attachments or share verification codes.

7. Business Continuity and Disaster Recovery

Business Continuity (BC): Keeping essential business operations running during and after a disruption.

Disaster Recovery (DR): Restoring IT systems, applications, and data after a disruption.

Business Continuity	Disaster Recovery
Focuses on continuing essential operations	Focuses on restoring IT services
May include alternative working arrangements	Includes restoring servers and backups
Example: Staff continue using an alternate office	Example: Restore a damaged database from backup

Important Terms

- Backup: A copy of data used for restoration.
- RTO (Recovery Time Objective): The target time within which a service should be restored.
- RPO (Recovery Point Objective): The maximum targeted amount of data loss measured in time.

Example: If the RTO is four hours, the service should be restored within four hours. If the RPO is one hour, recovery should aim to lose no more than one hour of data.

8. Quick Revision

- Risk management: Identify, assess, and treat risks.
- Risk assessment: Evaluate likelihood and impact.
- Mitigation: Reduce risk.
- Transfer: Share financial consequences.
- Avoidance: Stop the risky activity.
- Acceptance: Formally tolerate a risk.
- Security policy: Defines security rules and responsibilities.
- Business continuity: Keeps essential operations running.
- Disaster recovery: Restores IT systems and data.
- RTO: Target time to restore a service.
- RPO: Target maximum data-loss period.

Topic 9: Security Models & Principles 🔐

1. What are Security Models?

Definition: Security models are formal rules or frameworks that describe how a system should control access to information and protect its confidentiality and integrity.

Real-world example: A government system uses security classifications to decide which employees can access confidential documents.

2. Bell–LaPadula Model

Purpose: Protects confidentiality — preventing unauthorized disclosure of information.

Two main rules:

- No Read Up: A user cannot read information at a higher security level.
- No Write Down: A user cannot write information to a lower security level.

Example: An employee with Confidential clearance cannot read a Top Secret document or copy Top Secret information into a lower-classified document.

Remember: Bell–LaPadula = Confidentiality.

3. Biba Model

Purpose: Protects integrity — preventing unauthorized or improper modification of information.

Two main rules:

- No Read Down: A user at a higher integrity level should not read data from a lower integrity level.
- No Write Up: A user at a lower integrity level cannot write to a higher integrity level.

Example: A trusted financial system prevents low-integrity data from directly modifying high-integrity financial records.

Remember: Biba = Integrity.

4. Clark–Wilson Model

Purpose: Maintains data integrity through controlled and authorized transactions.

Main concepts:

- Only authorized transactions can modify protected data.
- Separation of duties helps prevent fraud.
- Auditing records important actions.

Example: In a bank, one employee initiates a large payment and another authorized employee approves it.

5. Defense in Depth

Definition: Defense in depth means using multiple layers of security so that if one control fails, other controls can still protect the system.

Layer 1: Physical Security

Locks, guards, restricted rooms

Layer 2: Network Security

Firewalls, IDS/IPS

Layer 3: System Security

Patching, endpoint protection

Layer 4: Data Security

Encryption, access controls, backups

Example: Even if an attacker bypasses a firewall, MFA and database permissions may still prevent access to sensitive records.

6. Principle of Least Privilege

Definition: Give each user or process only the minimum permissions necessary to perform its task.

Example: A cashier can generate receipts but cannot change administrator accounts or delete the entire database.

Benefit: Limits damage caused by mistakes or compromised accounts.

7. Separation of Duties

Definition: Divide important tasks between different people so that one person cannot complete a sensitive process alone.

Example: One employee prepares a payment, and another approves it.

Benefit: Reduces fraud, misuse, and unauthorized changes.

8. Zero Trust Security

Definition: Zero Trust is a security approach based on the principle “Never trust automatically; always verify.”

It does not automatically trust users or devices simply because they are inside an organization's network.

Main principles:

- Verify identity and device security.
- Grant minimum necessary access.
- Recheck access according to risk and context.
- Monitor activity continuously.

Example: An employee must verify their identity using MFA before accessing company files, even when connected to the office network.

9. Security by Design

Definition: Security by design means considering security requirements from the beginning of software or system development rather than adding them only at the end.

Example: A developer builds server-side authorization, secure password storage, and input validation into a university portal from the start.

10. Quick Revision

- Bell–LaPadula: Confidentiality; no read up, no write down.
- Biba: Integrity; no read down, no write up.
- Clark–Wilson: Integrity through authorized transactions and separation of duties.
- Defense in depth: Multiple security layers.
- Least privilege: Minimum necessary access.
- Separation of duties: Divide sensitive responsibilities.
- Zero Trust: Verify explicitly; do not trust automatically.
- Security by design: Build security into a system from the beginning.

Topic 10: Ethical Hacking & Security Tools 🛡

1. What is Ethical Hacking?

Definition: Ethical hacking is the authorized process of testing computer systems, networks, or applications to identify security weaknesses before malicious attackers exploit them.

Real-world example: A university hires a security professional to test its student portal for vulnerabilities.

Important: Ethical hacking must be performed with proper permission and a clearly defined scope.

2. Types of Hackers

- White Hat Hacker: An authorized security professional who identifies and fixes vulnerabilities.
- Black Hat Hacker: A malicious attacker who accesses systems without authorization.
- Gray Hat Hacker: Someone who may investigate vulnerabilities without permission but is not necessarily acting with malicious intent.

Example: A white hat hacker tests a company's website under a written agreement.

3. Penetration Testing

Definition: Penetration testing is an authorized security assessment in which testers attempt to exploit vulnerabilities to determine their real-world impact.

Main Stages

1

Planning and Permission

Define scope, objectives, and authorization.

2

Reconnaissance

Collect information about the target.

3

Scanning and Enumeration

Identify reachable services and potential weaknesses.

4

Controlled Exploitation

Safely verify vulnerabilities within the agreed scope.

5

Reporting

Document findings, evidence, severity, and impact.

6

Remediation and Retesting

Fix vulnerabilities and verify the fixes.

Example: A company authorizes a tester to examine its website, report weaknesses, and retest the application after developers fix them.

4. Vulnerability Assessment vs Penetration Testing

Vulnerability Assessment	Penetration Testing
Identifies and prioritizes weaknesses	Attempts to validate and exploit selected weaknesses

Focuses on finding potential vulnerabilities	Focuses on demonstrating security impact
Often uses automated scanning	Uses manual analysis and selected tools
Example: Finds outdated software	Example: Safely verifies whether the weakness permits unauthorized access

Both approaches are useful and may be used together.

5. Common Ethical Hacking Tools

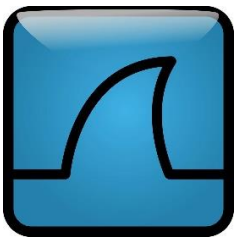


1. Nmap

A network discovery and port-scanning tool.

Use: Identify hosts, open ports, and running services on authorized targets.

Example: `nmap 192.168.1.10`



2. Wireshark

A network protocol analyzer that captures and examines packets.

Use: Troubleshoot network issues and investigate suspicious traffic.

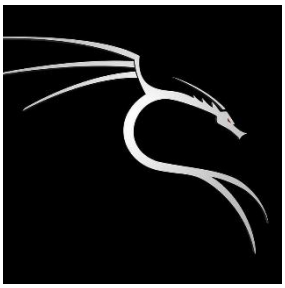
Example: Inspect DNS requests or TCP connection behavior on a network you are authorized to analyze.

3. Burp Suite

A toolkit for testing web application security.

Use: Inspect and test HTTP requests, responses, and application behavior.

Example: Test a practice login form for input-validation problems.

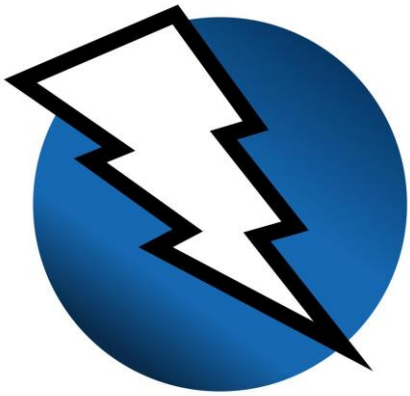


4. Kali Linux

A Linux distribution containing many security testing and digital forensics tools.

Use: Learn security testing in a controlled lab.

Example: Practice network scanning against a deliberately vulnerable virtual machine.



5. OWASP ZAP

A web application security testing tool.

Use: Help identify common web vulnerabilities in authorized test environments.

Example: Assess a locally hosted practice website for security misconfigurations.

6. Active vs Passive Reconnaissance

- Passive reconnaissance: Collect information without directly interacting with the target's systems in a probing manner.

  Example: Reviewing publicly available company information.

- Active reconnaissance: Directly interact with the target to gather information.

  Example: Scanning an authorized lab machine to discover open ports.

Active testing requires authorization because it can trigger alerts or disrupt services.

7. Common Linux Security Commands

These commands are useful for learning and administering your own Linux system.

```
whoami
```

Displays the current username.

```
ip addr
```

Displays network interfaces and their IP addresses.

```
ss -tuln
```

Lists listening TCP/UDP sockets.

```
ps aux
```

Displays running processes.

```
sudo apt update
```

Refreshes package information on Debian-based systems.

Example: On Kali Linux, these commands help you understand your user account, network configuration, running processes, and available software updates.

8. Responsible Security Testing

- Obtain written permission before testing.
- Test only systems within the agreed scope.
- Avoid accessing real users' private data.
- Do not disrupt services or destroy data.
- Keep evidence confidential.
- Report vulnerabilities responsibly.
- Retest after fixes are applied.

9. Quick Revision

- Ethical hacking: Authorized security testing.
- White hat: Authorized security professional.
- Penetration testing: Tests whether vulnerabilities can be exploited.
- Vulnerability assessment: Identifies and prioritizes weaknesses.
- Nmap: Network discovery and port scanning.
- Wireshark: Packet and protocol analysis.
- Burp Suite: Web application testing.
- Kali Linux: Security-focused Linux distribution.
- OWASP ZAP: Web vulnerability testing.
- Reconnaissance: Gathering information about a target.

Topic 11: Incident Response & Digital Forensics

1. What is Incident Response?

Definition: Incident response is the organized process of detecting, analyzing, containing, and recovering from cybersecurity incidents.

Real-world example: A university discovers ransomware on its server. The security team isolates the affected system, investigates the attack, and restores clean data from backups.

2. Types of Security Incidents

- Malware infection: Malicious software infects a system.
- Data breach: Sensitive information is accessed or disclosed without authorization.
- Phishing incident: A user is tricked into revealing credentials or opening a malicious attachment.
- Unauthorized access: Someone accesses a system without permission.
- Denial-of-Service attack: An attacker disrupts a service.
- Insider threat: An employee or other trusted person misuses their access, intentionally or accidentally.

3. Incident Response Lifecycle

1

Preparation

Create response plans, train staff, and prepare tools and backups.

2

Detection and Analysis

Identify suspicious activity, verify the incident, and assess its scope.

3

Containment

Limit damage by isolating affected devices or accounts.

4

Eradication

Remove malware, close vulnerabilities, and eliminate the cause.

5

Recovery

Restore systems safely and monitor for recurring activity.

6

Lessons Learned

Document findings and improve security controls and procedures.

Example: When a server is infected, the team isolates it, removes the infection, patches the vulnerability, restores clean data, and reviews how the incident occurred.

4. What is Digital Forensics?

Definition: Digital forensics is the process of identifying, collecting, preserving, examining, and presenting digital evidence in a reliable manner.

Real-world example: Investigators analyze computer logs and disk images to determine how an attacker accessed a company server.

Types of Digital Forensics

- Computer forensics: Examines computers, files, and storage devices.
- Network forensics: Examines network traffic and connection records.
- Mobile forensics: Examines digital evidence from phones and tablets.
- Memory forensics: Examines volatile memory (RAM) for running processes and other evidence.
- Cloud forensics: Investigates evidence from cloud services and environments.

5. Digital Evidence

Definition: Digital evidence is information stored or transmitted electronically that may help investigate an incident.

Examples:

- System and application logs.
- Emails and message records.
- Files and metadata.
- Network packet captures.
- Browser history.
- Disk images and memory captures.

Important: Evidence must be handled carefully so it is not altered, lost, or contaminated.

6. Chain of Custody

Definition: Chain of custody is a documented record of who collected, handled, transferred, stored, and examined evidence.

Purpose: It helps establish the evidence's authenticity and integrity.

Example: An investigator records when a laptop was collected, who secured it, who examined it, and where it was stored.

A chain-of-custody record commonly includes:

- Evidence identification.
- Date, time, and collection details.
- Name and signature of the responsible person.
- Every transfer of custody.
- Storage and access records.

7. Hashing in Digital Forensics

Definition: Hashing generates a fixed-length digest from digital data. A cryptographic hash can help detect changes to evidence.

Example: Investigators calculate the SHA-256 hash of a forensic disk image before and after transferring it. Matching hashes support the conclusion that the image has not changed.

Important: A hash helps verify integrity; it does not by itself prove who created the evidence or whether the original data was truthful.

8. Log Analysis

Definition: Log analysis involves examining recorded system, application, and network events to identify suspicious behavior and reconstruct activity.

Example: Repeated failed logins followed by a successful login from an unusual source may indicate a compromised account.

Common sources include:

- Authentication logs.
- Firewall logs.
- Web server logs.
- Operating system logs.

- Antivirus and endpoint detection logs.

Linux example:

```
sudo journalctl
```

Displays system journal entries on systems using `systemd`.

```
last
```

Displays recorded login sessions from the system's login history.

```
sudo tail -n 50 /var/log/auth.log
```

Displays the latest 50 lines of the authentication log on systems that use this file.

Note: Log file locations and available commands vary by Linux distribution and configuration.

9. Recovery and Lessons Learned

After an incident, organizations should:

- Restore from verified clean backups.
- Patch exploited vulnerabilities.
- Reset compromised credentials and revoke affected sessions.
- Monitor systems for signs of renewed compromise.
- Document the timeline and impact.
- Improve security controls and incident response procedures.

Example: After an employee account is compromised, a company resets credentials, enables MFA, reviews access logs, and updates its phishing-awareness training.

10. Quick Revision

- Incident response: Handles cybersecurity incidents systematically.
- Containment: Limits the spread and damage.
- Eradication: Removes the threat and its cause.
- Recovery: Restores systems to safe operation.
- Digital forensics: Examines digital evidence.
- Chain of custody: Records evidence handling.
- Hashing: Helps verify data integrity.
- Log analysis: Investigates recorded system activity.
- Lessons learned: Improves future security and response.

Topic 12: Cyber Security — Final Revision Notes 🔐

These are the most important concepts from all 11 topics for quick BS-level exam revision. As requested, notes only — no MCQs.

1. Security Fundamentals

- Information Security: Protecting information from unauthorized access, modification, disclosure, or destruction.
- CIA Triad:
  - Confidentiality — prevents unauthorized disclosure.
  - Integrity — prevents unauthorized modification.
  - Availability — ensures authorized access when needed.
- AAA: Authentication, Authorization, Accounting.
- Threat: Something that can cause harm.
- Vulnerability: A weakness in a system.
- Risk: Potential loss or harm.
- Exploit: A method of taking advantage of a vulnerability.
- Least Privilege: Giving only the minimum required permissions.

2. Security Attacks & Malware

- Passive attack: Monitors information without directly changing it.
- Active attack: Modifies, injects, or disrupts information or services.
- Virus: Attaches to a host file or program.
- Worm: Self-replicates and spreads across systems or networks.
- Trojan: Malicious software disguised as legitimate software.
- Ransomware: Encrypts or blocks data and demands payment.
- Phishing: Uses deceptive messages to steal information.
- DoS: Overwhelms a service.
- DDoS: Uses multiple systems to overwhelm a service.
- MITM: Intercepts communication between parties.

3. Cryptography

- Plaintext: Original readable data.
- Ciphertext: Encrypted data.
- Encryption: Converts readable data into protected ciphertext.
- Decryption: Converts ciphertext back into readable data.
- Symmetric encryption: Uses the same secret key; example: AES.
- Asymmetric cryptography: Uses a public/private key pair; examples: RSA and ECC.
- Hashing: Produces a fixed-length digest; examples: SHA-256 and SHA-3.

- Digital signature: Helps verify authenticity and integrity.
- Digital certificate: Binds an identity to a public key.
- PKI: Infrastructure for managing public-key certificates and trust.
- HTTPS: Protects web communication using TLS.

4. Authentication & Access Control

- Authentication: Verifies identity.
- Authorization: Determines permitted actions.
- MFA: Uses two or more different types of authentication factors.
- DAC: Resource owner controls access.
- MAC: Access follows centrally enforced security labels and clearances.
- RBAC: Access depends on job roles.
- ABAC: Access depends on attributes and rules.
- Password security: Use unique passwords, secure storage, and MFA.
- Accounting: Records user activities for monitoring and auditing.

5. Network Security

- Firewall: Filters network traffic.
- IDS: Detects suspicious activity and alerts.
- IPS: Detects suspicious activity and can block it.
- VPN: Creates an encrypted tunnel to a VPN endpoint.
- TLS: Protects communication through encryption, integrity, and authentication.
- SSH: Secure remote administration.
- WPA2/WPA3: Wireless network security standards.
- IP spoofing: Forges a packet's source IP address.
- DNS spoofing: Uses false DNS information to redirect traffic.
- Port scanning: Identifies accessible network ports and services.

6. System & Database Security

- System security: Protects operating systems, computers, and resources.
- File permissions: Control reading, writing, and execution.
- Patching: Fixes software vulnerabilities.
- Database security: Protects stored information.
- SQL injection: Unsafe input changes a database query.
- Parameterized queries: Help prevent SQL injection.
- Full backup: Copies all selected data.
- Incremental backup: Copies changes since the previous backup.
- Differential backup: Copies changes since the last full backup.
- Auditing: Records and reviews database activities.

7. Web & Application Security

- XSS: Malicious scripts execute in a user's browser.
- CSRF: Tricks an authenticated user's browser into sending an unwanted request.
- Session hijacking: Abuses a stolen or compromised session.
- Broken access control: Allows access beyond assigned permissions.
- Secure coding: Develops software with security protections built in.
- Cookies: Store small pieces of browser-related data.
- OWASP: Provides guidance on common web application security risks.
- Input validation and output encoding: Help reduce common injection and scripting vulnerabilities.

8. Risk Management & Security Policies

- Risk assessment: Evaluates threats, vulnerabilities, likelihood, and impact.
- Risk mitigation: Reduces risk.
- Risk transfer: Shares certain consequences with another party.
- Risk avoidance: Stops the activity creating the risk.
- Risk acceptance: Formally accepts a risk within approved limits.
- Security policy: Defines security rules and responsibilities.
- Business continuity: Keeps essential operations running.
- Disaster recovery: Restores IT services and data.
- RTO: Target time for service restoration.
- RPO: Target maximum data-loss period.

9. Security Models & Principles

- Bell–LaPadula: Protects confidentiality — no read up, no write down.
- Biba: Protects integrity — no read down, no write up.
- Clark–Wilson: Protects integrity through controlled transactions and separation of duties.
- Defense in depth: Uses multiple layers of protection.
- Least privilege: Grants minimum necessary access.
- Separation of duties: Divides sensitive tasks between people.
- Zero Trust: Verifies access rather than trusting automatically.
- Security by design: Incorporates security from the beginning of development.

10. Ethical Hacking & Security Tools

- Ethical hacking: Authorized security testing.
- Penetration testing: Attempts to validate and exploit selected vulnerabilities within an approved scope.
- Vulnerability assessment: Identifies and prioritizes weaknesses.
- Nmap: Network discovery and port scanning.
- Wireshark: Network packet and protocol analysis.
- Burp Suite: Web application security testing.
- Kali Linux: Linux distribution for security testing and related tasks.
- OWASP ZAP: Web application security testing.

- Reconnaissance: Gathering information about a target.

11. Incident Response & Digital Forensics

- Incident response: Handles cybersecurity incidents systematically.
- Preparation: Establishes plans, tools, and training.
- Detection and analysis: Identifies and investigates incidents.
- Containment: Limits damage.
- Eradication: Removes the threat and its cause.
- Recovery: Restores systems safely.
- Digital forensics: Collects and examines digital evidence.
- Chain of custody: Documents evidence handling and transfers.
- Hashing: Helps verify evidence integrity.
- Log analysis: Examines recorded system events.
- Lessons learned: Improves future security.

Important Comparisons for Exams

Concepts	Main difference
Threat vs Vulnerability	Potential source of harm vs system weakness
Authentication vs Authorization	Verifies identity vs grants permissions
Encryption vs Hashing	Reversible with the appropriate key vs designed as one-way
Symmetric vs Asymmetric	Same secret key vs public/private key pair
IDS vs IPS	Detects and alerts vs can detect and block
Virus vs Worm	Requires a host file/program vs can self-replicate across networks
DoS vs DDoS	One or fewer sources vs distributed sources
Bell–LaPadula vs Biba	Confidentiality vs integrity
Vulnerability Assessment vs Penetration Testing	Finds and prioritizes weaknesses vs tests their exploitability
Business Continuity vs Disaster Recovery	Continues essential operations vs restores IT systems and data

Final Exam Preparation Strategy

1. Learn the definitions and one real-world example for every major topic.
2. Memorize the CIA Triad, AAA, access-control models, risk-treatment methods, and incident-response lifecycle.
3. Practice writing comparisons in clear points.
4. For long questions, write a definition, main concepts or steps, an example, and a short conclusion.

5. Revise the tools, their purposes, and the security attacks they help investigate.